DuocUC | Escuela de Informática y Telecomunicaciones

# VERIFICACIÓN DE CALIDAD, SEGURIDAD Y CUMPLIMIENTO NORMATIVO

## Tramoya: gestión de eventos para productoras

### Informe de seguridad y calidad en el desarrollo de software

**ISY1102 - Seguridad y calidad en el desarrollo de software**
Evaluación Parcial N°3
Carrera: Ingeniería en Informática
Sección 002D
Docente: Erwin Enrique Aguilera Segura

**Integrante**
Jonathan Larraguibel

Fecha: 28-10-2026

# ÍNDICE

1. Introducción....3
2. Criterios de calidad....5
3. Plan de pruebas....7
3.1 Estrategia de pruebas....7
3.2 Tipos de prueba....7
3.3 Criterios de aceptación....8
3.4 Herramientas utilizadas....9
3.5 Trazabilidad con el ERS....10
3.6 Análisis de cobertura y coherencia....11
3.7 Objetivos, alcance y cronograma....12
4. Diseño de casos de prueba....13
5. Ejecución de pruebas....19
5.1 Resumen de ejecución....19
5.2 Detalle de ejecución de casos....19
5.3 Criticidad de incidentes....21
6. Análisis ético y normativo....25
7. Conclusiones y recomendaciones....27
8. Informe de certificación final....28
Anexo A. Evidencia de ejecución....30
Anexo B. Descripción del producto....36

# 1. Introducción

## 1.1 Contexto del software evaluado

Tramoya es una plataforma web para productoras de eventos pequeñas (ferias, conciertos, matrimonios y eventos corporativos). Permite registrar a los clientes organizadores con su RUT, crear los eventos que contratan con fecha, recinto, aforo y monto en pesos, adjuntar la cotización y el contrato en PDF, confirmar los eventos, compartir la cotización con el cliente mediante un enlace y llevar un registro de auditoría de quién hizo cada cambio. Cada productora tiene administradores y coordinadores de solo lectura. El código está disponible en https://github.com/jhonnylarry/tramoya y el producto se especifica en docs/ERS_Tramoya.md con 45 requisitos: 17 funcionales, 20 no funcionales y 8 reglas de negocio.

Tramoya maneja datos personales (RUT y contacto de los clientes) e información comercial (montos y contratos). Una falla de seguridad expone datos de terceros y una falla funcional se traduce en pérdidas concretas: una doble reserva de recinto, un evento confirmado sin contrato o una cotización con precios vencidos.

## 1.2 Propósito del plan de pruebas

Verificar con evidencia ejecutable si Tramoya cumple sus requisitos de calidad, seguridad y normativa, documentar los defectos con su criticidad y recomendación, y emitir un dictamen de certificación (sección 8). Se busca que cada requisito tenga al menos un caso (cobertura de diseño del 100 %), que los controles críticos se prueben con casos negativos y que cada prueba responda a una necesidad del negocio con su criterio de aceptación.

## 1.3 Alcance

Tramoya se construyó sobre un código base propio, desarrollado por el autor en una etapa anterior del curso, adaptado a este dominio y a los requisitos de docs/ERS_Tramoya.md.

Alcance real de los resultados: (a) el producto y las pruebas son del mismo autor, sin revisión independiente; (b) se usa SQLite en lugar de PostgreSQL, por lo que los tiempos de carga son referenciales; (c) no hubo pruebas con usuarios ni operación en producción; (d) todos los datos son sintéticos. Las pruebas se ejecutaron el 28-10-2026 en el equipo del estudiante (macOS, Apple Silicon, Node.js 26.10, Docker 29.4).

## 1.4 Ajustes realizados desde la Evaluación Parcial 1

La EP1 obtuvo 84/100. Lo que se trasladó a esta evaluación es el aprendizaje sobre cómo construir el plan de pruebas. La tabla resume cada observación y el ajuste aplicado.

| Indicador EP1 (puntaje) | Observación recibida | Ajuste aplicado en este informe | Sec. |
|---|---|---|---|
| Importancia de la calidad, la seguridad y el cumplimiento legal (12/15) | Conceptos correctos, con ejemplos limitados. | Cada criterio se liga a un requisito del ERS de Tramoya y a una pérdida concreta para la productora (por ejemplo, una doble reserva de recinto si falla RB-6). Se agrega la normativa chilena aplicable con su efecto sobre el diseño. | 2 |
| Pruebas no funcionales y su contexto (16/20) | Cubre la mayoría de los tipos, con justificación parcial o poco profunda. | Cada tipo no funcional se justifica por el riesgo que cubre, tiene umbral tomado del ERS, herramienta y casos. Se ejecutan además JMeter (rendimiento), SonarQube (estático), Lighthouse, tres motores de navegador y despliegue en Docker. | 3.2, 4, 5 |
| Elementos del plan de pruebas y su vínculo con requisitos y normas (20/25) | Incluye la mayoría de los apartados, con vínculos poco detallados. | Matriz de trazabilidad de los 45 requisitos del ERS de Tramoya contra los 53 casos, con el estado de cada uno. Cada caso nuevo declara qué pierde la productora si falla. | 3.1, 3.4, 3.5 |
| Cobertura, pertinencia y coherencia del plan (16/20) | Buena coherencia general, con análisis superficial. | Se separa cobertura de diseño (100 %) de cobertura de ejecución (95,6 %) y de cobertura de código, y se analiza qué no se pudo verificar y por qué. | 3.6, 5.1, 6 |
| Clasificación de tipos de prueba (20/20) | Sin observaciones. | Se mantiene la clasificación y se amplía con análisis estático en SonarQube, rendimiento con JMeter, compatibilidad multimotor y despliegue en contenedor. | 3.2 |

## 1.5 Estructura del informe

Sección 2: criterios de calidad, seguridad y normativa. Sección 3: plan de pruebas con estrategia, tipos, criterios de aceptación, herramientas, trazabilidad y cobertura. Sección 4: diseño de casos. Sección 5: ejecución, con resumen, detalle e incidentes. Sección 6: análisis ético y normativo. Sección 7: conclusiones. Sección 8: informe de certificación final con dictamen. Los anexos contienen la evidencia y la descripción del producto.

## 2. Criterios de calidad

Los criterios se derivan del ERS de Tramoya y se ordenan según ISO/IEC 25010. Para cada uno se indica el requisito y la consecuencia de su incumplimiento para una productora.

### 2.1 Calidad

- **Adecuación funcional.** Las reglas RB-6 a RB-8 son el núcleo del negocio. Ejemplo: si RB-6 falla, dos eventos quedan confirmados en el mismo recinto y fecha; uno se cae y la productora debe devolver el anticipo e indemnizar.
- **Usabilidad.** NFR-USAB-1 a USAB-4: tipografía legible, contraste, teclado, mensajes claros y el flujo cliente → eventos. Ejemplo: si el mensaje de RUT inválido no explica el formato, la persona que administra la productora no logra registrar al cliente.
- **Rendimiento.** NFR-PERF-1 (promedio menor a 300 ms), NFR-PERF-2 (página en menos de 2 s en móvil) y NFR-PERF-3 (200 usuarios). Ejemplo: el coordinador revisa el evento desde el celular en el recinto, con mala señal.
- **Fiabilidad y disponibilidad.** NFR-DIS-1 (99,5 % mensual) y NFR-SEG-7 (respaldo). Ejemplo: perder los contratos la semana de un evento detiene la operación.
- **Compatibilidad.** NFR-COMPAT-1 y COMPAT-2: Chrome, Firefox, Safari y Edge, en móvil y tablet.
- **Mantenibilidad.** Se mide con SonarQube; el código con defectos sin documentar encarece corregir problemas de seguridad después.

### 2.2 Seguridad

- **Protección de datos.** NFR-SEG-1 (TLS), SEG-2 (bcrypt) y SEG-3 (cifrado en reposo). Ejemplo: sin cifrado, un respaldo extraviado expone contratos con montos y RUT.
- **Control de acceso.** NFR-SEG-4, RB-2 y RB-4. Ejemplo: sin verificación de pertenencia, cambiar el identificador en la URL mostraría los clientes de otra productora.
- **Entrada y disponibilidad del servicio.** NFR-SEG-5: validación de entrada, protección contra inyección, límite de intentos y dependencias sin vulnerabilidades altas. Ejemplo: una validación mal construida puede bloquear el servidor con una sola solicitud (INC-16).
- **Trazabilidad.** RF-6.1 y NFR-SEG-6: quién confirmó un evento o cambió un monto, sin guardar credenciales.
- **Sesión.** NFR-SEG-9: JWT con secreto propio y vigencia corta.

### 2.3 Normativa y estándares

| Norma o estándar | Qué exige | Requisitos relacionados | Cómo se verifica |
|---|---|---|---|
| Ley 19.628, Protección de la vida privada | Tratamiento de datos personales con finalidad y medidas de seguridad. | RF-4 (clientes con RUT), NFR-SEG-3, NFR-SEG-8 | Revisión de campos almacenados, cifrado y flujo de eliminación (NF-02, NF-09). |
| Ley 21.719, Protección de Datos Personales (vigencia diferida hasta fines de 2026) | Derechos de acceso, rectificación, supresión, oposición y portabilidad; deber de seguridad y de reportar brechas. | RF-4.2, NFR-SEG-3, NFR-SEG-6, NFR-SEG-8 | Verificar supresión real de datos y registros que permitan investigar una brecha (NF-09, CP-27). |
| Ley 19.799, Documentos electrónicos y firma electrónica | Los contratos digitales deben conservar integridad y autoría. | RF-5.2, RF-5.3, RF-6.1, RB-7 | El contrato PDF se guarda sin alterarse, la confirmación lo exige y su subida queda auditada (CP-21, CP-25, CP-34). |
| Ley 21.459, Delitos informáticos | El acceso no autorizado a sistemas es delito; las pruebas deben estar autorizadas. | Todo el plan | Las pruebas de seguridad y carga se ejecutan solo sobre el producto propio, con datos sintéticos. |
| Ley 21.663, Marco de ciberseguridad | Gestión de riesgos y reporte de incidentes. En una productora pequeña se toma como referencia de buenas prácticas. | NFR-SEG-6, NFR-SEG-7 | Clasificación de incidentes y plan de remediación (5.3 y 8). |
| ISO/IEC 25010, Modelo de calidad del producto | Adecuación funcional, eficiencia, compatibilidad, usabilidad, fiabilidad, seguridad y mantenibilidad. | Sección 2 y catálogo de casos | Cada caso se asocia a una característica; SonarQube entrega calificaciones de fiabilidad, seguridad y mantenibilidad. |
| ISO/IEC 27001 | Controles de seguridad de la información (control de acceso, criptografía, registros, respaldo). | NFR-SEG-1 a SEG-9 | Los incidentes de seguridad se contrastan con los controles que faltan (sección 8). |
| OWASP Top 10 (2021) | Catálogo de riesgos de seguridad web. | NFR-SEG-1 a SEG-9 | Cada incidente se clasifica según su categoría OWASP (5.3). |
| WCAG 2.1 nivel AA | Contraste, teclado, etiquetas y tamaño de objetivo táctil. | NFR-USAB-1 a USAB-3 | axe-core sobre tres pantallas en tres motores, navegación con teclado y tamaño de controles (NF-12). |
| ISO/IEC/IEEE 29119, Pruebas de software | Proceso y documentación de pruebas. | Secciones 3 a 5 y 8 | Estructura del plan, diseño, reporte de ejecución e informe de certificación. |

Tensión a vigilar: RF-4.2 pide eliminación lógica (útil para no perder eventos asociados), mientras la Ley 21.719 reconoce el derecho de supresión. Ambos se cumplen si, además de la eliminación lógica, existe supresión o anonimización a solicitud del titular; se evalúa en NF-09.

# 3. Plan de pruebas

## 3.1 Estrategia de pruebas

- **Enfoque mixto.** Funcionales y de seguridad de la API automatizadas con Jest y Supertest; rendimiento con JMeter; análisis estático con SonarQube, ESLint y njsscan; dependencias con npm audit; frontend con Playwright y axe-core en tres motores; página principal con Lighthouse; despliegue con Docker. Lo que las herramientas no detectan (TLS, cifrado, supresión de datos) se revisa con una lista de comprobación por requisito.
- **Etapas.** (1) Redacción del ERS de Tramoya y extracción de los 45 requisitos; (2) diseño de casos y trazabilidad; (3) entorno con datos sintéticos; (4) análisis estático y de dependencias; (5) casos funcionales y de seguridad; (6) carga; (7) frontend; (8) revisión de configuración y normativa; (9) clasificación de incidentes; (10) informe de certificación.
- **Priorización por riesgo.** Primero lo que expone datos de otra productora o credenciales, luego las reglas que generan pérdidas económicas directas (RB-6, RB-7, RB-8), y al final rendimiento, usabilidad y compatibilidad.
- **Criterios de entrada.** ERS de Tramoya cerrado; producto compilado; herramientas instaladas con versión registrada; datos sintéticos.
- **Criterios de salida.** Los 45 requisitos con al menos un caso; todos los casos ejecutables ejecutados; cada incidente con criticidad y recomendación. El producto no se certifica con incidentes críticos o graves abiertos.

## 3.2 Tipos de prueba

| Tipo de prueba | Propósito | Requisitos | Por qué es necesaria en Tramoya | Herramienta |
|---|---|---|---|---|
| Funcionales (caja negra sobre la API) | Confirmar que cada RF y RB se comporta según su criterio de aceptación. | RF-1 a RF-6, RB-1 a RB-8 | Un evento confirmado sin contrato o un recinto reservado dos veces genera pérdidas directas a la productora. | Jest + Supertest |
| Seguridad: control de acceso y aislamiento | Verificar que cada rol solo hace lo que le corresponde y que una productora no ve datos de otra. | NFR-SEG-4, RF-3.2, RB-2, RB-4 | Una productora de la competencia vería clientes, montos y contratos. | Jest + Supertest (casos negativos) |
| Seguridad: inyección y validación de entrada | Comprobar que SQL injection, XSS y archivos falsos no prosperan, y que el RUT y el monto se validan. | NFR-SEG-5, RF-4.3, RF-5.2, RB-8 | Un PDF falso podría ser malware enviado al cliente; un RUT inválido impide facturar. | Jest + revisión de consultas |
| Seguridad: autenticación y sesión | Hash de contraseñas, política de claves, revocación de token, secreto JWT y fuerza bruta. | NFR-SEG-2, SEG-9, RF-1 | Si el secreto del JWT es conocido, cualquiera fabrica un token de administrador. | Jest, script de verificación |

| Tipo de prueba | Propósito | Requisitos | Por qué es necesaria en Tramoya | Herramienta |
|---|---|---|---|---|
| Seguridad: configuración y transporte | TLS, cabeceras de seguridad, CORS y cifrado en reposo. | NFR-SEG-1, SEG-3 | Sin cifrado, un respaldo robado expone contratos con montos y RUT. | Script de verificación, revisión de código |
| Seguridad: dependencias | Detectar componentes con vulnerabilidades conocidas. | NFR-SEG-5 | Una dependencia vulnerable permite denegación de servicio sin fallas en el código propio. | npm audit |
| Análisis estático de código | Detectar patrones inseguros, defectos de fiabilidad y deuda técnica sin ejecutar el sistema. | NFR-SEG-5, mantenibilidad (ISO 25010) | Encuentra defectos temprano; en este proyecto encontró una expresión regular explotable (INC-16). | SonarQube, ESLint + plugin de seguridad, njsscan |
| Rendimiento y carga | Medir tiempo de respuesta y errores con 10 y 200 usuarios concurrentes. | NFR-PERF-1, PERF-3 | En temporada alta (fiestas patrias, fin de año) todo el equipo consulta a la vez. | JMeter (principal), autocannon (contraste) |
| Rendimiento de página y vulnerabilidades del frontend | Medir carga de la página principal y buenas prácticas. | NFR-PERF-2 | El equipo de terreno consulta desde el celular en recintos con mala señal. | Lighthouse |
| Usabilidad y accesibilidad | Legibilidad, contraste, teclado y mensajes claros para personas mayores. | NFR-USAB-1 a USAB-4 | Parte de la administración de las productoras son personas mayores que usan el sistema ocasionalmente. | Playwright + axe-core; pruebas con usuarios pendientes |
| Compatibilidad | Funcionamiento en Chrome, Firefox, Safari y Edge, y en móvil y tablet. | NFR-COMPAT-1, COMPAT-2 | Muchos coordinadores usan iPhone (Safari). | Playwright con Chromium, Firefox y WebKit |
| Disponibilidad, recuperación y despliegue | Respaldos restaurables, imagen Docker funcional y disponibilidad mensual. | NFR-DIS-1, DIS-2, NFR-SEG-7 | Perder los contratos la semana de un evento detiene la operación. | Jest (respaldo), Docker, monitoreo en producción (pendiente) |
| Cumplimiento normativo | Contrastar el sistema con la normativa de datos personales. | NFR-SEG-8 | Multas y pérdida de confianza de los clientes. | Checklist Ley 19.628 y 21.719 |

## 3.3 Criterios de aceptación

- Funcional: el resultado coincide con el esperado y el código HTTP corresponde (2xx en casos válidos, 4xx en casos inválidos o sin permiso).
- Reglas de negocio: se cumplen RB-1 a RB-8 en todos los casos (aislamiento por productora, coordinador solo lectura, recinto sin doble reserva, contrato antes de confirmar, monto entero en pesos).
- Seguridad: ningún caso permite acceder a datos de otra productora ni a funciones de otro rol; el sistema no se certifica con hallazgos críticos o graves abiertos.
- Rendimiento: tiempo promedio menor a 300 ms y error menor a 1 % con 10 y 200 usuarios (NFR-PERF-1 y PERF-3, JMeter); subida de un PDF de 5 MB en menos de 10 s; LCP menor a 2 s en móvil (NFR-PERF-2).

- Usabilidad y compatibilidad: cero violaciones WCAG 2.1 A y AA detectadas por axe-core; controles de 44 px; flujos completos en Chromium, Firefox y WebKit; sin desplazamiento horizontal en 375, 768 y 1440 px.
- Datos: cada registro de auditoría tiene usuario, fecha, acción y objeto; ninguno contiene contraseñas ni hashes.
- Un caso que cumple el resultado esperado pero deja una observación de seguridad o rendimiento se registra como «aprobado con observaciones» y abre un incidente.

## 3.4 Herramientas utilizadas

| Herramienta y versión | Uso en este plan | Fundamento de la elección |
|---|---|---|
| Jest 30.5.2 + Supertest 7.3.1 | 39 pruebas automatizadas de la API (CP-01 a CP-37 y dos de respaldo) y cobertura de código. | La regresión completa se repite en menos de 10 segundos, incluidos los casos negativos de seguridad. Es la prueba unitaria «dentro del código» que pide el docente. |
| Apache JMeter 5.6.3 | Plan jmeter/plan_tramoya.jmx en modo no gráfico: 10 y 200 usuarios, rampa de 5 s, 30 s por escenario, dos consultas autenticadas. | Herramienta indicada por el docente para rendimiento; entrega promedio, percentiles, error y un reporte HTML. |
| SonarQube Community 26.10 (Docker) + SonarScanner | Análisis estático de src, frontend/src y scripts, con la cobertura de Jest. | Herramienta indicada por el docente para análisis estático; califica fiabilidad, seguridad y mantenibilidad. |
| ESLint 8.57.1 + eslint-plugin-security 4.2.0 y njsscan 1.0.2 | Análisis estático complementario orientado a patrones inseguros de Node.js. | Reglas específicas de Express que SonarQube no cubre igual, como rutas de archivo construidas con datos del usuario. |
| npm audit (npm 11.19.1) | Dependencias de producción contra avisos de seguridad. | Detecta vulnerabilidades en componentes de terceros. |
| Google Lighthouse 13.5.0 | Rendimiento, accesibilidad y buenas prácticas de la página principal, en móvil y escritorio. | Herramienta indicada por el docente; entrega el LCP para NFR-PERF-2 y revisa buenas prácticas de seguridad del frontend. |
| Playwright 1.64.1 + axe-core 4.14.0 | 18 verificaciones de extremo a extremo por motor (Chromium 156, Firefox 157 y WebKit 27.2): flujos, RB-7 en la interfaz, teclado, tamaño de controles, WCAG 2.1 y diseño responsivo. | Permite probar en un navegador real los tres motores de los cuatro navegadores del ERS (Edge usa Chromium). |
| autocannon 8.0.0 | Carga HTTP complementaria sobre el listado de clientes. | Sirve de contraste independiente de JMeter. |
| Docker 29.4.3 | Construcción y ejecución de la imagen con docker_verificar.sh. | Verifica que el producto se despliega en contenedor con usuario sin privilegios. |

### *Recursos humanos*

Trabajo formalmente grupal realizado de forma individual: los roles de analista, tester y revisor de seguridad los asumió el mismo autor. Se declara como limitación (3.6).

### *Recursos técnicos y entorno*

Node.js 26.10, npm 11.19, Express 4.19.2, React 19.1 con Vite 8.3, SQLite embebido (node:sqlite), Java 24 para JMeter, Docker 29.4 con SonarQube Community 26.10. Ambiente local aislado en el equipo del estudiante, sin datos reales. La base de datos de las pruebas

automatizadas es en memoria y se reinicia en cada caso. Para la carga, servidor y generador corren en la misma máquina, lo que penaliza los resultados. La imagen Docker es de dos etapas y ejecuta la API con un usuario sin privilegios.

### 3.5 Trazabilidad con el ERS

Cada requisito del ERS de Tramoya con los casos que lo verifican y su estado tras la ejecución.

| Requisito | Descripción | Casos | Estado tras la ejecución |
|---|---|---|---|
| **RF-1.1** | Inicio de sesión | CP-01, CP-02 | Conforme |
| **RF-1.2** | Cierre de sesión y revocación | CP-03 | Con incidente (INC-10) |
| **RF-2.1** | Registro de usuario | CP-05, CP-06 | Conforme |
| **RF-2.2** | Creación de productora | CP-07 | Conforme |
| **RF-2.3** | Primer usuario es administrador | CP-07 | Conforme |
| **RF-3.1** | Agregar usuarios y asignar rol | CP-09 | Conforme |
| **RF-3.2** | Coordinador solo consulta | CP-10, CP-36 | Conforme |
| **RF-3.3** | Cambiar rol o quitar usuario | CP-11 | Conforme |
| **RF-4.1** | Crear y listar clientes | CP-13, CP-30 | Conforme |
| **RF-4.2** | Editar y eliminar con confirmación | CP-15 | Conforme |
| **RF-4.3** | Validar tipo, RUT y nombre | CP-14, CP-17, CP-31, CP-32 | Conforme |
| **RF-5.1** | Crear evento con fecha, recinto, aforo y monto | CP-18, CP-19 | Conforme |
| **RF-5.2** | Cotización y contrato solo en PDF | CP-21, CP-22, CP-29 | Conforme |
| **RF-5.3** | Almacenamiento interno con referencia | CP-21 | Conforme |
| **RF-5.4** | Estados del evento y confirmación | CP-20, CP-28, CP-34 | Conforme |
| **RF-5.5** | Enlace de cotización | CP-23, CP-37 | Conforme |
| **RF-6.1** | Auditoría de acciones críticas | CP-25 | Conforme |
| **NFR-SEG-1** | TLS en todas las comunicaciones | NF-01 | Con incidente (INC-03, INC-09) |
| **NFR-SEG-2** | Hash bcrypt | CP-05 | Conforme |
| **NFR-SEG-3** | Cifrado en reposo | NF-02 | Con incidente (INC-04) |
| **NFR-SEG-4** | Control de acceso en backend | CP-10, CP-12, CP-24, CP-26, CP-36 | Conforme |
| **NFR-SEG-5** | Entrada, intentos y dependencias | CP-14, CP-16, CP-17, NF-03, NF-05, NF-06 | Con incidente (INC-01, 05, 11, 16) |
| **NFR-SEG-6** | Registros sin credenciales | CP-27 | Conforme |
| **NFR-SEG-7** | Respaldo y recuperación | NF-10 | Conforme (con observación) |
| **NFR-SEG-8** | Datos personales | NF-09 | Con incidente (INC-06) |
| **NFR-SEG-9** | Sesión JWT | CP-04, NF-04 | Con incidente (INC-02) |
| **NFR-PERF-1** | CRUD < 300 ms, error < 1 % | NF-07, CP-29 | Conforme |
| **NFR-PERF-2** | Página < 2 s en móvil | NF-11 | Conforme |

| Requisito | Descripción | Casos | Estado tras la ejecución |
|---|---|---|---|
| **NFR-PERF-3** | 200 usuarios concurrentes | NF-08 | Conforme |
| **NFR-USAB-1** | Legibilidad para personas mayores | NF-12 | Parcial (sin pruebas con usuarios) |
| **NFR-USAB-2** | Navegación con teclado | NF-12, NF-13 | Con incidente (INC-15) |
| **NFR-USAB-3** | Mensajes de error claros | NF-12 | Con incidente (INC-12) |
| **NFR-USAB-4** | Primero el cliente, luego sus eventos | CP-28 | Conforme |
| **NFR-DIS-1** | Disponibilidad 99,5 % | NF-14 | No verificado (requiere producción) |
| **NFR-DIS-2** | Mantenimiento planificado | NF-14 | No verificado (requiere producción) |
| **NFR-COMPAT-1** | Chrome, Firefox, Safari y Edge | NF-13 | Con incidente (INC-15) |
| **NFR-COMPAT-2** | Diseño responsivo | NF-13 | Conforme |
| **RB-1** | Correo único por productora | CP-08 | Conforme |
| **RB-2** | Aislamiento entre productoras | CP-12 | Conforme |
| **RB-3** | Evento de un solo cliente | CP-18 | Conforme |
| **RB-4** | Coordinador solo lectura | CP-10, CP-36 | Conforme |
| **RB-5** | Administrador con acceso completo | CP-13, CP-15, CP-18, CP-21 | Conforme |
| **RB-6** | Recinto sin doble reserva | CP-35 | Conforme |
| **RB-7** | Contrato antes de confirmar | CP-34, E2E-05 | Conforme |
| **RB-8** | Monto entero; enlace vence a 7 días | CP-33, NF-15 | Con incidente (INC-08) |

## 3.6 Análisis de cobertura y coherencia

- **Cobertura de diseño: 100 %.** Los 45 requisitos (17 RF, 20 NFR y 8 RB) tienen al menos un caso. Se diseñaron 53 casos: 37 automatizados (CP) y 16 no funcionales (NF). Cada requisito nuevo de Tramoya (RF-4.3, RF-5.1, RF-5.2, RF-5.4, RF-5.5, RB-6, RB-7 y RB-8) tiene al menos un caso con criterio de aceptación y justificación de negocio.
- **Cobertura de ejecución: 95,6 % (43 de 45 requisitos).** NFR-DIS-1 y DIS-2 requieren producción. De los 43 ejecutados, 32 quedaron conformes, 10 con incidente y 1 parcial (NFR-USAB-1, sin pruebas con usuarios mayores).
- **Cobertura de código.** Jest: 85,0 % de sentencias, 73,7 % de ramas, 88,0 % de funciones y 93,3 % de líneas de la API. SonarQube informa 68,9 % porque incluye el frontend, que se prueba con Playwright y no con Jest.

Pertinencia. Los casos negativos (CP-10, 12, 16, 17, 22, 24, 26, 36 y NF-03) y los no funcionales son los que encontraron los defectos: los 37 casos automatizados aprueban, pero fallan cinco casos de seguridad, uno de reglas de negocio, uno de análisis estático y uno

normativo. Los umbrales se tomaron literalmente del ERS y los hallazgos se contrastaron con OWASP, ISO/IEC 25010 y la normativa chilena.

Limitaciones. (1) Sin revisión independiente existe sesgo de confirmación. (2) La carga se midió en una sola máquina, con SQLite y sin red real. (3) CSRF no aplica por diseño: el token viaja en la cabecera Authorization y no en cookies. (4) No hubo pruebas con usuarios ni en dispositivos físicos; Edge no se probó por separado (usa el motor Chromium). (5) No se hicieron pruebas de penetración más allá de inyección, control de acceso, fuerza bruta y la denegación de servicio por expresión regular.

## 3.7 Objetivos, alcance y cronograma

### *Objetivos*

- Verificar los 45 requisitos del ERS de Tramoya con al menos un caso cada uno y un criterio de aceptación medible.
- Auditar el código con análisis estático (SonarQube, ESLint, njsscan) y de dependencias (npm audit), y clasificar cada hallazgo según OWASP y CWE.
- Medir el rendimiento con JMeter frente a NFR-PERF-1 y NFR-PERF-3, y la carga de la página con Lighthouse frente a NFR-PERF-2.
- Contrastar los resultados con la Ley 19.628, la Ley 21.719, ISO/IEC 25010 e ISO/IEC 27001, y emitir un dictamen de certificación.

### *Alcance*

Incluido: la API, el frontend, la imagen Docker, los respaldos y los tres motores de navegador. Excluido: operación en producción y medición de disponibilidad, pruebas con usuarios reales, base PostgreSQL y pruebas de penetración completas. Lo excluido se declara como limitación y como condición del dictamen (sección 8).

### *Cronograma*

| Actividad | Fecha | Estado |
|---|---|---|
| Especificación del ERS y diseño de casos con trazabilidad | 28-10-2026 | Realizado |
| Análisis estático y de dependencias (SonarQube, ESLint, njsscan, npm audit) | 28-10-2026 | Realizado |
| Pruebas funcionales, reglas de negocio y seguridad (Jest) | 28-10-2026 | Realizado |
| Rendimiento (JMeter, autocannon) y página principal (Lighthouse) | 28-10-2026 | Realizado |
| Interfaz en Chromium, Firefox y WebKit; despliegue en Docker | 28-10-2026 | Realizado |
| Clasificación de incidentes, informe y dictamen | 28-10-2026 | Realizado |
| Ciclo 2: corregir INC-02 e INC-16 y repetir NF-04 y NF-06 | Antes de cualquier despliegue | Pendiente |
| Ciclo 3: corregir INC-01, 03, 04 y 05; repetir la suite completa y SonarQube | Después del ciclo 2 | Pendiente |
| Pruebas con cinco usuarios y medición de disponibilidad | Antes de producción | Pendiente |

## 4. Diseño de casos de prueba

El catálogo lista los 53 casos con su requisito y tipo. Luego se detallan 10 casos, priorizando los requisitos nuevos de Tramoya y los que piden las herramientas del docente (JMeter, SonarQube, compatibilidad). Las demás fichas están en el código de prueba (test/tramoya.test.js).

### 4.1 Catálogo de casos

| ID | Nombre | Requerimiento | Tipo de prueba |
|---|---|---|---|
| **CP-01** | Login exitoso entrega JWT | RF-1.1 | Funcional |
| **CP-02** | Login con clave incorrecta | RF-1.1 | Funcional / Seguridad |
| **CP-03** | Logout revoca el token | RF-1.2 | Funcional |
| **CP-04** | Acceso sin token a recurso protegido | NFR-SEG-9 | Seguridad |
| **CP-05** | Contraseña almacenada con hash bcrypt | NFR-SEG-2, RF-2.1 | Seguridad |
| **CP-06** | Política de contraseñas | RF-2.1 | Funcional / Seguridad |
| **CP-07** | Quien crea la productora queda como administrador | RF-2.2, RF-2.3 | Funcional |
| **CP-08** | Correo de productora no puede repetirse | RB-1 | Regla de negocio |
| **CP-09** | Administrador asigna rol coordinador | RF-3.1 | Funcional |
| **CP-10** | Coordinador no puede crear clientes | RF-3.2, RB-4, NFR-SEG-4 | Seguridad (control de acceso) |
| **CP-11** | Administrador quita a un usuario del equipo | RF-3.3 | Funcional |
| **CP-12** | Aislamiento de datos entre productoras | RB-2, NFR-SEG-4 | Seguridad (control de acceso) |
| **CP-13** | Crear y listar clientes con paginación y filtro | RF-4.1, RB-5 | Funcional |
| **CP-14** | Nombre de cliente con caracteres no permitidos | RF-4.3, NFR-SEG-5 | Funcional / Seguridad |
| **CP-15** | Eliminación lógica con confirmación | RF-4.2, RB-5 | Funcional |
| **CP-16** | SQL injection en filtro de clientes | NFR-SEG-5 | Seguridad |
| **CP-17** | XSS almacenado en campo libre | NFR-SEG-5, RF-4.3 | Seguridad |
| **CP-18** | Crear evento asociado a un cliente (queda cotizado) | RF-5.1, RB-3, RB-5 | Funcional |
| **CP-19** | Fecha, recinto o aforo inválidos | RF-5.1 | Funcional (validación) |
| **CP-20** | Estado del evento según confirmación y fecha | RF-5.4 | Lógica de negocio |
| **CP-21** | Subir contrato PDF a almacenamiento interno | RF-5.2, RF-5.3, RB-5 | Funcional |
| **CP-22** | Rechazo de .exe y de PDF falso | RF-5.2 | Funcional / Seguridad |
| **CP-23** | Enlace de cotización descarga la cotización | RF-5.5 | Funcional |
| **CP-24** | Descarga de documento de otra productora | NFR-SEG-4 | Seguridad (control de acceso) |
| **CP-25** | Auditoría de acciones críticas | RF-6.1 | Funcional |
| **CP-26** | Coordinador no puede leer la auditoría | NFR-SEG-4 | Seguridad (control de acceso) |
| **CP-27** | Auditoría sin contraseñas ni hashes | NFR-SEG-6 | Seguridad (registros) |
| **CP-28** | Flujo cliente → eventos con estado calculado | NFR-USAB-4, RF-5.4 | Funcional / Usabilidad |
| **CP-29** | Subida de un PDF de 5 MB en menos de 10 s | RF-5.2 | Rendimiento |
| **CP-30** | Cliente sin campos opcionales (regresión INC-14) | RF-4.1 | Regresión |
| **CP-31** | RUT con dígito verificador incorrecto | RF-4.3 | Funcional (validación) |

| ID | Nombre | Requerimiento | Tipo de prueba |
|---|---|---|---|
| **CP-32** | Tipo de cliente desconocido | RF-4.3 | Funcional (validación) |
| **CP-33** | Monto no entero o no positivo | RB-8 | Regla de negocio |
| **CP-34** | No se confirma un evento sin contrato PDF | RB-7, RF-5.4 | Regla de negocio |
| **CP-35** | No hay dos eventos confirmados en el mismo recinto y fecha | RB-6 | Regla de negocio |
| **CP-36** | Coordinador no confirma eventos ni adjunta documentos | RB-4, RF-3.2 | Seguridad (control de acceso) |
| **CP-37** | Sin cotización no se genera enlace | RF-5.5 | Funcional |
| **NF-01** | TLS, cabeceras de seguridad y CORS | NFR-SEG-1, NFR-SEG-5 | Seguridad (configuración) |
| **NF-02** | Cifrado de documentos en reposo | NFR-SEG-3 | Seguridad (configuración) |
| **NF-03** | Fuerza bruta sobre el login | NFR-SEG-5 | Seguridad |
| **NF-04** | Secreto de firma del JWT | NFR-SEG-9 | Seguridad |
| **NF-05** | Dependencias con vulnerabilidades conocidas | NFR-SEG-5 | Seguridad (dependencias) |
| **NF-06** | Análisis estático (SonarQube, ESLint, njsscan) | NFR-SEG-5, mantenibilidad | Análisis estático |
| **NF-07** | Respuesta promedio menor a 300 ms con 10 usuarios (JMeter) | NFR-PERF-1 | Rendimiento |
| **NF-08** | 200 usuarios concurrentes (JMeter) | NFR-PERF-3 | Carga |
| **NF-09** | Cumplimiento de protección de datos personales | NFR-SEG-8 | Normativa |
| **NF-10** | Respaldo y recuperación | NFR-SEG-7 | Disponibilidad |
| **NF-11** | Página principal en menos de 2 s en móvil | NFR-PERF-2 | Rendimiento (frontend) |
| **NF-12** | Usabilidad y accesibilidad | NFR-USAB-1, USAB-2, USAB-3 | Usabilidad |
| **NF-13** | Compatibilidad en tres motores y tres tamaños | NFR-COMPAT-1, COMPAT-2 | Compatibilidad |
| **NF-14** | Disponibilidad mensual y mantenimiento | NFR-DIS-1, NFR-DIS-2 | Disponibilidad |
| **NF-15** | Vencimiento y revocación del enlace de cotización | RB-8 | Regla de negocio / Seguridad |
| **NF-16** | Despliegue en contenedor Docker | Arquitectura (ERS 2) | Despliegue |

## 4.2 Casos detallados

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **CP-35** | No hay dos eventos confirmados en el mismo recinto y fecha | RB-6 | Regla de negocio |
| **DESCRIPCIÓN** | | | |
| Verificar que el sistema impide confirmar un segundo evento en un recinto que ya tiene un evento confirmado ese día. Justificación de negocio: una doble reserva obliga a cancelar un evento y a indemnizar al cliente. | | | |
| **PRECONDICIONES** | | | |
| Productora con un cliente y tres eventos: dos en «Centro Cultural Estacion» el 10-07-2027 (uno escrito en minúsculas) y uno el 11-07-2027; los tres con contrato PDF. | | | |
| **PASOS** | | | |
| 1. Confirmar el primer evento.<br>2. Confirmar el segundo (mismo recinto, misma fecha).<br>3. Confirmar el tercero (mismo recinto, otra fecha). | | | |
| **DATOS DE PRUEBA** | | | |

| |
|---|
| recinto: «Centro Cultural Estacion» y «centro cultural estacion» \| fechas: 2027-07-10 y 2027-07-11 |
| **RESULTADO ESPERADO** |
| Paso 1: 200. Paso 2: 409 «Recinto ocupado en esa fecha». Paso 3: 200. |
| **CRITERIO DE ACEPTACIÓN** |
| El choque se detecta sin importar mayúsculas y solo bloquea la misma fecha. |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **CP-34** | No se confirma un evento sin contrato PDF | RB-7, RF-5.4 | Regla de negocio |
| **DESCRIPCIÓN** | | | |
| Comprobar que confirmar exige el contrato adjunto, aunque exista la cotización. Justificación de negocio: movilizar equipo y proveedores sin contrato deja a la productora sin respaldo legal si el cliente se retracta. | | | |
| **PRECONDICIONES** | | | |
| Evento cotizado con su cotización PDF adjunta y sin contrato. | | | |
| **PASOS** | | | |
| 1. POST /api/eventos/{id}/confirmar.<br>2. Adjuntar el contrato PDF.<br>3. Repetir la confirmación. | | | |
| **DATOS DE PRUEBA** | | | |
| tipo: cotizacion y luego contrato (contenido %PDF-1.4) | | | |
| **RESULTADO ESPERADO** | | | |
| Paso 1: 409 «El evento no tiene contrato adjunto». Paso 3: 200 con estado confirmado. | | | |
| **CRITERIO DE ACEPTACIÓN** | | | |
| Ningún evento llega a confirmado sin contrato; la interfaz muestra el mismo mensaje (E2E-05a). | | | |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **CP-31** | RUT con dígito verificador incorrecto | RF-4.3 | Funcional (validación) |
| **DESCRIPCIÓN** | | | |
| Verificar que el RUT del cliente se valida con el algoritmo de módulo 11. Justificación de negocio: una cotización emitida a un RUT inexistente no se puede facturar. | | | |
| **PRECONDICIONES** | | | |
| Productora con administrador autenticado. | | | |
| **PASOS** | | | |
| 1. Crear clientes con RUT 76.086.428-4, 12345678-K, 1234-5 y abc.<br>2. Crear un cliente persona con RUT 12.345.678-5. | | | |
| **DATOS DE PRUEBA** | | | |
| Cuatro RUT inválidos y uno válido | | | |
| **RESULTADO ESPERADO** | | | |
| Paso 1: 400 en los cuatro. Paso 2: 201. | | | |
| **CRITERIO DE ACEPTACIÓN** | | | |
| Solo se aceptan RUT con dígito verificador correcto. | | | |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **CP-33** | Monto no entero o no positivo | RB-8 | Regla de negocio |
| **DESCRIPCIÓN** | | | |
| Verificar que el monto del evento es un entero en pesos mayor que cero. Justificación de negocio: un monto en cero o con decimales produce cotizaciones que no se pueden facturar. | | | |

| PRECONDICIONES |
|---|
| Cliente existente. |
| **PASOS** |
| 1. Crear un evento con cada monto de prueba.<br>2. Revisar código y mensaje. |
| **DATOS DE PRUEBA** |
| 0 \| -1000 \| 1500.5 \| «4500000» (texto) \| null |
| **RESULTADO ESPERADO** |
| 400 «Monto invalido» en los cinco. |
| **CRITERIO DE ACEPTACIÓN** |
| No se guarda ningún evento con monto inválido. |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **CP-12** | Aislamiento de datos entre productoras | RB-2, NFR-SEG-4 | Seguridad (control de acceso) |
| **DESCRIPCIÓN** | | | |
| Verificar que el administrador de la productora B no puede leer ni modificar datos de la productora A. Justificación de negocio: los clientes y montos son información comercial de la competencia. | | | |
| **PRECONDICIONES** | | | |
| Productoras A y B con administradores distintos; A tiene un cliente. | | | |
| **PASOS** | | | |
| 1. Autenticarse como administrador de B.<br>2. Listar clientes de A.<br>3. Editar el cliente de A con PUT /api/clientes/{id}. | | | |
| **DATOS DE PRUEBA** | | | |
| nombre: Hack | | | |
| **RESULTADO ESPERADO** | | | |
| Ambas solicitudes responden 403. | | | |
| **CRITERIO DE ACEPTACIÓN** | | | |
| Cero datos de A visibles o modificables desde B. | | | |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **CP-22** | Rechazo de .exe y de PDF falso | RF-5.2 | Funcional / Seguridad |
| **DESCRIPCIÓN** | | | |
| Comprobar que solo se aceptan PDF reales: extensión .pdf y firma %PDF al inicio. Justificación de negocio: el enlace de cotización entrega el archivo al cliente; un ejecutable disfrazado expondría al cliente a malware. | | | |
| **PRECONDICIONES** | | | |
| Evento existente. | | | |
| **PASOS** | | | |
| 1. Subir malo.exe.<br>2. Subir un archivo de contenido MZ llamado contrato.pdf. | | | |
| **DATOS DE PRUEBA** | | | |
| malo.exe \| contrato.pdf con contenido «MZ ejecutable» | | | |
| **RESULTADO ESPERADO** | | | |
| 400 «Formato no permitido» en ambos. | | | |
| **CRITERIO DE ACEPTACIÓN** | | | |

| |
|---|
| Ningún archivo que no sea PDF queda almacenado. |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **NF-08** | 200 usuarios concurrentes con JMeter | NFR-PERF-3, NFR-PERF-1 | Carga |
| **DESCRIPCIÓN** | | | |
| Medir tiempo de respuesta y error con 200 usuarios simultáneos. Justificación de negocio: en temporada alta todo el equipo consulta clientes y eventos al mismo tiempo. | | | |
| **PRECONDICIONES** | | | |
| Servidor recién iniciado; productora con 30 clientes y un evento; token JWT válido. | | | |
| **PASOS** | | | |
| 1. Ejecutar jmeter/ejecutar.sh 200 (modo no gráfico, rampa 5 s, 30 s).<br>2. Revisar statistics.json y el reporte HTML. | | | |
| **DATOS DE PRUEBA** | | | |
| GET /api/productoras/{id}/clientes?pagina=1&tam=10 y GET /api/clientes/{id}/eventos | | | |
| **RESULTADO ESPERADO** | | | |
| Promedio menor a 300 ms y error menor a 1 %. | | | |
| **CRITERIO DE ACEPTACIÓN** | | | |
| Promedio < 300 ms y error < 1 %. | | | |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **NF-06** | Análisis estático con SonarQube | NFR-SEG-5, mantenibilidad | Análisis estático |
| **DESCRIPCIÓN** | | | |
| Analizar el código con SonarQube, con la cobertura de Jest, y clasificar cada hallazgo. Justificación de negocio: los defectos encontrados antes del despliegue cuestan menos que un incidente con clientes. | | | |
| **PRECONDICIONES** | | | |
| SonarQube Community en Docker; cobertura lcov generada por Jest. | | | |
| **PASOS** | | | |
| 1. Ejecutar sonar-scanner sobre src, frontend/src y scripts.<br>2. Consultar medidas, incidencias y puntos críticos por la API.<br>3. Reproducir los hallazgos de seguridad. | | | |
| **DATOS DE PRUEBA** | | | |
| 816 líneas de código | | | |
| **RESULTADO ESPERADO** | | | |
| Sin vulnerabilidades ni defectos de fiabilidad abiertos; calificaciones A. | | | |
| **CRITERIO DE ACEPTACIÓN** | | | |
| Calificación de seguridad A y ningún hallazgo explotable. | | | |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **NF-15** | Vencimiento y revocación del enlace de cotización | RB-8 | Regla de negocio / Seguridad |
| **DESCRIPCIÓN** | | | |
| Comprobar que el enlace deja de funcionar a los 7 días y que se puede revocar. Justificación de negocio: una cotización antigua con precios vencidos sigue circulando y el cliente puede exigirla. | | | |
| **PRECONDICIONES** | | | |
| Evento con cotización y enlace generado. | | | |

| PASOS |
|---|
| 1. Generar el enlace.<br>2. Simular el paso de 8 días y descargar.<br>3. Buscar una ruta para revocar el enlace. |
| **DATOS DE PRUEBA** |
| Reloj adelantado 8 días |
| **RESULTADO ESPERADO** |
| Descarga rechazada (410 o 404) y existencia de una ruta de revocación. |
| **CRITERIO DE ACEPTACIÓN** |
| El enlace vence y puede revocarse. |

| ID | NOMBRE | REQUERIMIENTO | TIPO DE PRUEBA |
|---|---|---|---|
| **NF-13** | Compatibilidad en tres motores | NFR-COMPAT-1, COMPAT-2 | Compatibilidad |
| **DESCRIPCIÓN** | | | |
| Repetir las 18 verificaciones de extremo a extremo en Chromium, Firefox y WebKit. Justificación de negocio: muchos coordinadores trabajan desde iPhone (Safari). | | | |
| **PRECONDICIONES** | | | |
| Frontend compilado servido por Express; navegadores de Playwright instalados. | | | |
| **PASOS** | | | |
| 1. MOTOR=chromium node e2e/e2e.js.<br>2. MOTOR=firefox.<br>3. MOTOR=webkit. | | | |
| **DATOS DE PRUEBA** | | | |
| Usuario y productora sintéticos por ejecución | | | |
| **RESULTADO ESPERADO** | | | |
| 18 de 18 en cada motor. | | | |
| **CRITERIO DE ACEPTACIÓN** | | | |
| NFR-COMPAT-1 conforme solo si pasan los tres motores. | | | |

## 5. Ejecución de pruebas

Las pruebas se ejecutaron el 28-10-2026 por Jonathan Larraguibel sobre Tramoya (Anexo B). Los resultados provienen de ejecutar las herramientas y sus salidas están en la carpeta evidencia y en el Anexo A. No se alteró ningún resultado. Las primeras corridas de JMeter respondieron 401 en el 100 % de las solicitudes porque el script de preparación no obtuvo un token válido del servidor de prueba (no estaba listo o quedó otro proceso en el puerto). Se descartaron por ser fallas del montaje de la prueba y no del producto, y se repitieron con un script que espera al servidor y lo inicia limpio (jmeter/ejecutar.sh).

### 5.1 Resumen de ejecución

| Indicador | Cantidad | Detalle |
|---|---|---|
| **Casos diseñados** | 53 | 37 automatizados (CP-01 a CP-37) y 16 no funcionales (NF-01 a NF-16) |
| **Casos ejecutados** | 52 | 98,1 % de los diseñados |
| **Aprobados** | 40 | 36 CP (todos salvo CP-03), NF-07, NF-08, NF-11 y NF-16 |
| **Aprobados con observaciones** | 4 | CP-03 (INC-10), NF-10 (respaldo sin cifrar), NF-12 y NF-13 (INC-12, INC-15) |
| **Fallidos** | 8 | NF-01 a NF-05 (seguridad), NF-06 (estático), NF-09 (normativa) y NF-15 (RB-8) |
| **Sin ejecutar** | 1 | NF-14: requiere producción |
| **Pruebas automatizadas** | 39 / 39 | Jest: 37 CP y 2 de respaldo |
| **Verificaciones de interfaz** | 52 / 54 | 18 por motor: Chromium 18, Firefox 18, WebKit 16 |
| **Incidentes** | 16 | 1 crítico, 6 graves, 6 moderados y 3 leves; 13 abiertos, 2 cerrados (INC-13, INC-14) y 1 no reproducido (INC-07) |

Lectura. Las nuevas reglas de negocio de Tramoya funcionan: RB-6, RB-7 y la parte de monto de RB-8 se cumplen en la API y RB-7 también en la interfaz. Los defectos están en seguridad, en el vencimiento del enlace de cotización y en un hallazgo nuevo de SonarQube (INC-16) que ninguna de las otras herramientas detectó. En requisitos: 32 de 45 conformes (71,1 %), 10 con incidente (22,2 %), 1 parcial (2,2 %) y 2 sin verificar (4,4 %).

### 5.2 Detalle de ejecución de casos

Todos los casos se ejecutaron el 28-10-2026. Los fallidos o con observaciones tienen su incidente en 5.3.

***PRUEBAS FUNCIONALES Y REGLAS DE NEGOCIO (28-10-2026, Jonathan Larraguibel)***

| CASO | DESCRIPCIÓN | RESULTADO | EVIDENCIA | INCIDENTE |
|---|---|---|---|---|
| **CP-01** | Login exitoso entrega JWT | Aprobado | A.1 | — |
| **CP-02** | Login con clave incorrecta | Aprobado | A.1 | — |
| **CP-03** | Logout revoca el token | Aprobado con observaciones | A.1 | INC-10 |
| **CP-06** | Política de contraseñas | Aprobado | A.1 | — |
| **CP-07** | Creador es administrador | Aprobado | A.1 | — |

| CASO | DESCRIPCIÓN | RESULTADO | EVIDENCIA | INCIDENTE |
|---|---|---|---|---|
| **CP-08** | Correo de productora único (RB-1) | Aprobado | A.1 | — |
| **CP-09** | Asignación de rol coordinador | Aprobado | A.1 | — |
| **CP-11** | Quitar usuario del equipo | Aprobado | A.1 | — |
| **CP-13** | Clientes con paginación y filtro | Aprobado | A.1 | — |
| **CP-14** | Nombre inválido | Aprobado | A.1 | — |
| **CP-15** | Eliminación lógica con confirmación | Aprobado | A.1 | — |
| **CP-18** | Crear evento cotizado | Aprobado | A.1 | — |
| **CP-19** | Fecha, recinto o aforo inválidos | Aprobado | A.1 | — |
| **CP-20** | Estado del evento | Aprobado | A.1 | — |
| **CP-21** | Subir contrato PDF | Aprobado | A.1 | — |
| **CP-22** | Rechazo de .exe y PDF falso | Aprobado | A.1 | — |
| **CP-23** | Enlace de cotización | Aprobado | A.1 | — |
| **CP-25** | Auditoría de acciones críticas | Aprobado | A.1 | — |
| **CP-28** | Flujo cliente → eventos | Aprobado | A.1 | — |
| **CP-30** | Cliente sin campos opcionales | Aprobado | A.1 | — |
| **CP-31** | RUT con dígito incorrecto | Aprobado | A.1 | — |
| **CP-32** | Tipo de cliente desconocido | Aprobado | A.1 | — |
| **CP-33** | Monto inválido (RB-8) | Aprobado | A.1 | — |
| **CP-34** | Confirmar sin contrato (RB-7) | Aprobado | A.1, A.7 | — |
| **CP-35** | Doble reserva de recinto (RB-6) | Aprobado | A.1 | — |
| **CP-37** | Enlace sin cotización | Aprobado | A.1 | — |
| **NF-15** | Vencimiento y revocación del enlace (RB-8) | Fallido | A.6 | INC-08 |

### *PRUEBAS DE SEGURIDAD (28-10-2026, Jonathan Larraguibel)*

| CASO | DESCRIPCIÓN | RESULTADO | EVIDENCIA | INCIDENTE |
|---|---|---|---|---|
| **CP-04** | Acceso sin token | Aprobado | A.1 | — |
| **CP-05** | Hash bcrypt | Aprobado | A.1 | — |
| **CP-10** | Coordinador no crea clientes | Aprobado | A.1 | — |
| **CP-12** | Aislamiento entre productoras | Aprobado | A.1 | — |
| **CP-16** | SQL injection | Aprobado | A.1 | — |
| **CP-17** | XSS almacenado | Aprobado | A.1 | — |
| **CP-24** | Documento de otra productora | Aprobado | A.1 | — |
| **CP-26** | Coordinador no lee auditoría | Aprobado | A.1 | — |
| **CP-27** | Auditoría sin credenciales | Aprobado | A.1 | — |
| **CP-36** | Coordinador no confirma ni adjunta | Aprobado | A.1 | — |
| **NF-01** | TLS, cabeceras y CORS | Fallido | A.6 | INC-03, INC-09 |
| **NF-02** | Cifrado en reposo | Fallido | Revisión de código | INC-04 |
| **NF-03** | Fuerza bruta en login | Fallido | A.6 | INC-05 |
| **NF-04** | Secreto del JWT | Fallido | A.6 | INC-02 |
| **NF-05** | Dependencias vulnerables | Fallido | A.4 | INC-01 |

***ANÁLISIS ESTÁTICO, NORMATIVO Y DESPLIEGUE (28-10-2026, Jonathan Larraguibel)***

| CASO | DESCRIPCIÓN | RESULTADO | EVIDENCIA | INCIDENTE |
|---|---|---|---|---|
| **NF-06** | SonarQube, ESLint y njsscan | Fallido | A.2, A.3 | INC-11, INC-16 |
| **NF-09** | Datos personales | Fallido | Revisión de código | INC-06 |
| **NF-10** | Respaldo y recuperación | Aprobado con observaciones | A.9 | — |
| **NF-16** | Despliegue en Docker | Aprobado | A.10 | — |

***PRUEBAS DE RENDIMIENTO Y CARGA (28-10-2026, Jonathan Larraguibel)***

| CASO | DESCRIPCIÓN | RESULTADO | EVIDENCIA | INCIDENTE |
|---|---|---|---|---|
| **CP-29** | PDF de 5 MB en menos de 10 s | Aprobado (19 a 24 ms en las corridas) | A.1 | — |
| **NF-07** | 10 usuarios, JMeter | Aprobado (promedio 1,08 ms, 0 % error) | A.5 | — |
| **NF-08** | 200 usuarios, JMeter | Aprobado (promedio 29,32 ms, 0 % error) | A.5 | — |
| **NF-11** | Página principal en móvil | Aprobado (LCP 1.396 ms) | A.8 | — |

***USABILIDAD Y COMPATIBILIDAD (28-10-2026, Jonathan Larraguibel)***

| CASO | DESCRIPCIÓN | RESULTADO | EVIDENCIA | INCIDENTE |
|---|---|---|---|---|
| **NF-12** | Usabilidad y accesibilidad | Aprobado con observaciones | A.7 | INC-12, INC-15 |
| **NF-13** | Tres motores y tres tamaños | Aprobado con observaciones (WebKit 16/18) | A.7 | INC-15 |

***NO EJECUTADAS (requieren producción) (28-10-2026, Jonathan Larraguibel)***

| CASO | DESCRIPCIÓN | RESULTADO | EVIDENCIA | INCIDENTE |
|---|---|---|---|---|
| **NF-14** | Disponibilidad mensual y mantenimiento | No ejecutado | Requiere operación en producción | — |

## 5.3 Criticidad de incidentes

Escala de cuatro niveles adaptada a Tramoya: la criticidad depende de si se exponen datos de clientes, de si afecta a una o a todas las productoras y de la pérdida económica directa.

| NIVEL | DESCRIPCIÓN | IMPACTO | ACCIÓN REQUERIDA |
|---|---|---|---|
| **CRITICO** | Permite vulnerar la seguridad de todo el sistema o impide una función esencial. Bloquea la puesta en producción. | Muy alto: compromete a todas las productoras | Remediación inmediata |
| **GRAVE** | Afecta un control o función importante; el sistema opera parcialmente y hay riesgo concreto de explotación. | Alto: datos de clientes o continuidad del servicio | Corrección urgente |
| **MODERADO** | Afecta funciones secundarias o casos específicos sin detener el flujo principal. | Medio: se trabaja con limitaciones | Próxima iteración |

| NIVEL | DESCRIPCIÓN | IMPACTO | ACCIÓN REQUERIDA |
|---|---|---|---|
| **LEVE** | Defecto de texto, apariencia o buena práctica sin efecto funcional relevante. | Bajo | Según disponibilidad |

Incidentes, ordenados por criticidad:

| ID | CASO | DESCRIPCIÓN | REQUISITO | CRITICIDAD |
|---|---|---|---|---|
| **INC-02** | NF-04 | El secreto de firma del JWT tiene un valor por defecto en el código (tramoya-dev-secret) cuando no se define JWT_SECRET. Un token firmado con ese valor es aceptado. | NFR-SEG-9 | **CRITICO** |
| **INC-01** | NF-05 | Express 4.19.2 y sus dependencias arrastran 9 vulnerabilidades: 4 altas (body-parser, compression, path-to-regexp, express), 1 moderada (qs) y 4 bajas. Respecto del 25-10 aparecieron avisos nuevos para compression y on-headers. | NFR-SEG-5 | **GRAVE** |
| **INC-03** | NF-01 | El servidor atiende en HTTP sin TLS ni redirección; no hay cabecera Strict-Transport-Security. | NFR-SEG-1 | **GRAVE** |
| **INC-04** | NF-02 | Las cotizaciones y contratos se guardan sin cifrar en el directorio storage. | NFR-SEG-3 | **GRAVE** |
| **INC-05** | NF-03 | Tras 30 intentos fallidos el intento correcto sigue siendo aceptado: no hay límite de intentos. | NFR-SEG-5 | **GRAVE** |
| **INC-14** | E2E / CP-30 | Detectado en una iteración anterior: la interfaz no creaba clientes con campos opcionales vacíos. Corregido y cubierto por CP-30, que sigue aprobando en Tramoya. | RF-4.1 | **GRAVE** |
| **INC-16** | NF-06 | SonarQube (regla S8786) marcó la expresión regular de validación de correo. Se reprodujo: un correo de 95.003 caracteres enviado a /api/auth/register, sin autenticación, mantiene ocupado el proceso 8,3 s, tiempo en que no atiende a nadie más. El largo máximo se revisa después de la expresión regular. | NFR-SEG-5 | **GRAVE** |
| **INC-06** | NF-09 | La eliminación de clientes es solo lógica y no hay supresión definitiva ni plazo de retención para los datos personales (incluido el RUT). | NFR-SEG-8, RF-4.2 | **MODERADO** |
| **INC-07** | NF-08 | Detectado en una medición anterior: 3 timeouts con 200 conexiones en otro entorno. En el equipo del estudiante, con JMeter y con autocannon, no se reprodujo (0 errores; máximo 312 ms en JMeter y 2.297 ms en autocannon). | NFR-PERF-3 | **MODERADO** |
| **INC-08** | NF-15, CP-23 | El enlace de cotización no vence ni se puede revocar: ocho días después la descarga sigue respondiendo 200, y no existe ruta de revocación. Incumple RB-8. | RB-8 | **MODERADO** |
| **INC-09** | NF-01, NF-06 | Se expone X-Powered-By: Express, faltan cabeceras de seguridad y CORS está abierto (*). SonarQube lo confirma (S5689 y S5122). | NFR-SEG-5 | **MODERADO** |
| **INC-10** | CP-03 | La revocación de tokens se guarda en memoria: se pierde al reiniciar y no sirve con más de una instancia. | RF-1.2 | **MODERADO** |
| **INC-13** | NF-11 | Detectado en una iteración anterior: LCP de 2,08 s sin compresión. Cerrado; en Tramoya el LCP móvil es 1.396 ms. | NFR-PERF-2 | **MODERADO** |

| ID | CASO | DESCRIPCIÓN | REQUISITO | CRITICIDAD |
|---|---|---|---|---|
| **INC-11** | NF-06 | Hallazgos estáticos sin documentar: ESLint-security 7 advertencias (falsos positivos revisados); SonarQube 9 promesas sin manejo de error en el frontend (fiabilidad), 2 usos de parseInt y un límite de subida de 10 MB marcado para revisión (S5693). njsscan 1 advertencia de recorrido de rutas (CWE-22) en la descarga de documentos, falso positivo porque la ruta es un nombre generado por el sistema. | Mantenibilidad | **LEVE** |
| **INC-12** | NF-12 | Los mensajes de error de la API no tienen tildes ni eñes («contrasena»). El frontend los traduce en los flujos probados, pero otros clientes de la API reciben el texto original. | NFR-USAB-3 | **LEVE** |
| **INC-15** | NF-13 | En WebKit (Safari) el primer Tab va al campo Usuario y no al enlace «Saltar al contenido», porque Safari por defecto no incluye enlaces en el orden de tabulación. E2E-07 falla en consecuencia: su secuencia de teclas supone ese enlace. El inicio de sesión con teclado sí es posible empezando desde el campo. | NFR-USAB-2, NFR-COMPAT-1 | **LEVE** |

Clasificación y recomendación:

| ID | OWASP / NORMA | RECOMENDACIÓN | ACCIÓN |
|---|---|---|---|
| **INC-02** | A02 / A07 | Quitar el valor por defecto y abortar el arranque si JWT_SECRET no está definido; rotar el secreto. | Inmediata |
| **INC-01** | A06 | Actualizar Express y compression a versiones corregidas y repetir npm audit. | Urgente |
| **INC-03** | A02 / A05 | Terminar TLS en un proxy inverso y agregar HSTS. | Urgente |
| **INC-04** | A02 | Cifrar con AES-256-GCM antes de escribir y administrar la clave fuera del repositorio. | Urgente |
| **INC-05** | A07 | Limitar intentos por IP y por usuario, con bloqueo temporal y registro en auditoría. | Urgente |
| **INC-14** | — | Mantener pruebas de integración entre interfaz y API. | Cerrado |
| **INC-16** | A04 (CWE-1333) | Revisar el largo antes de evaluar la expresión regular y usar una expresión sin retroceso; agregar un caso de regresión. | Urgente |
| **INC-06** | Ley 21.719 | Agregar anonimización o supresión a solicitud del titular, con plazo de retención definido. | Próxima iteración |
| **INC-07** | — | Repetir con PostgreSQL y en la infraestructura de producción antes de cerrarlo definitivamente. | En observación |
| **INC-08** | A01 / A04 | Guardar la fecha de creación del enlace, rechazar después de 7 días, agregar revocación y auditar cada descarga. | Próxima iteración |
| **INC-09** | A05 | Usar helmet, deshabilitar X-Powered-By y restringir CORS al origen del frontend. | Próxima iteración |
| **INC-10** | A07 | Guardar la lista de revocación en la base o en un almacén compartido. | Próxima iteración |
| **INC-13** | — | Mantener la compresión activa. | Cerrado |
| **INC-11** | — | Agregar manejo de error a las promesas, documentar las supresiones y mantener SonarQube en la integración continua. | Según disponibilidad |
| **INC-12** | — | Corregir los textos y centralizarlos. | Según disponibilidad |

| ID | OWASP / NORMA | RECOMENDACIÓN | ACCIÓN |
|---|---|---|---|
| **INC-15** | WCAG 2.4.1 | Convertir el enlace en un control enfocable en Safari (por ejemplo, tabindex=0) y ajustar la prueba para que no dependa del orden de tabulación del navegador. | Según disponibilidad |

Distribución de los 16 incidentes: 1 crítico, 6 graves, 6 moderados y 3 leves. INC-16 lo detectó solo SonarQube e INC-15 solo la prueba en WebKit; INC-08 incumple una regla de negocio propia de Tramoya (RB-8).

# 6. Análisis ético y normativo de los resultados

## 6.1 Protección de datos personales

Tramoya almacena el RUT y los datos de contacto de personas que contratan eventos; la productora es responsable del tratamiento y Tramoya es el encargado. INC-04 (documentos sin cifrar) e INC-03 (sin TLS) incumplen el deber de seguridad de la Ley 19.628 y de la Ley 21.719, que además obliga a notificar brechas. INC-06 muestra la tensión entre la eliminación lógica del ERS y el derecho de supresión. INC-08 tiene también una arista de datos: un enlace de cotización que no vence deja accesible, sin límite de tiempo, un documento con el nombre del cliente y el monto. Las pruebas usaron solo datos sintéticos.

## 6.2 Responsabilidad profesional en seguridad

INC-02 (secreto JWT por defecto) e INC-16 (expresión regular explotable) muestran dos caras del mismo deber: configuración segura por defecto y revisión del código con herramientas adecuadas. INC-16 no lo detectaron 37 casos funcionales, ESLint ni njsscan; lo encontró SonarQube y se confirmó reproduciéndolo. Corresponde informarlo con su evidencia y sin minimizarlo, aunque todos los casos funcionales aprueben.

## 6.3 Integridad del proceso de pruebas

El producto y las pruebas son del mismo autor y no hubo revisión independiente; dos requisitos no se pudieron verificar y uno se verificó en parte. Presentar el 100 % de casos funcionales aprobados como prueba de calidad habría sido engañoso; por eso se separan las coberturas de diseño, ejecución y código, y se informan los casos fallidos y las corridas descartadas tal como ocurrieron.

## 6.4 Inclusión y accesibilidad

Cero violaciones WCAG 2.1 A y AA en tres pantallas y tres motores, controles de 44 px, tipografía base de 16 px y accesibilidad 100 en Lighthouse. Sin embargo, no hubo pruebas con personas mayores, y en Safari el enlace para saltar al contenido no es alcanzable con Tab (INC-15). La evidencia técnica no reemplaza la prueba con usuarios; NFR-USAB-1 queda como parcial.

## 6.5 Uso autorizado de las herramientas

La fuerza bruta, la inyección, la denegación de servicio por expresión regular y la carga con 200 usuarios se ejecutaron solo sobre el producto propio, en un entorno local. Hacerlo sobre sistemas ajenos sin autorización puede constituir delito según la Ley 21.459.

## 6.6 Análisis estático frente a criterios legales y normativos

La tabla compara cada hallazgo del análisis estático y de dependencias con el criterio técnico (OWASP, CWE) y con la norma que se ve afectada.

| Hallazgo | Herramienta | Clasificación | Criterio normativo afectado | Consecuencia |
|---|---|---|---|---|
| Expresión regular del correo con retroceso (INC-16) | SonarQube S8786 | CWE-1333, OWASP A04 | ISO/IEC 25010 (disponibilidad); Ley 21.663 (gestión de incidentes) | Una solicitud sin cuenta detiene el servicio 8,3 s |
| Dependencias con vulnerabilidades conocidas (INC-01) | npm audit | OWASP A06 | Ley 21.719 (deber de seguridad); ISO/IEC 27001 (gestión de vulnerabilidades técnicas) | Denegación de servicio y XSS documentados públicamente |
| CORS abierto y versión expuesta (INC-09) | SonarQube S5122 y S5689 | CWE-942, CWE-200, OWASP A05 | ISO/IEC 27001 (configuración segura); Ley 19.628 (medidas de seguridad) | Facilita peticiones desde sitios ajenos y el reconocimiento del servidor |
| Ruta de archivo en la descarga (INC-11) | njsscan | CWE-22, OWASP A01 | Ley 19.628 y 21.719 (confidencialidad de documentos con datos personales) | Falso positivo verificado: la ruta es un nombre generado |
| Límite de subida de 10 MB (INC-11) | SonarQube S5693 | CWE-770 | ISO/IEC 25010 (eficiencia) | Consumo de memoria; cubre RF-5.2 (5 MB), conviene ajustarlo |
| Promesas sin manejo de error (INC-11) | SonarQube S9383 | Fiabilidad | ISO/IEC 25010 (fiabilidad) | Errores silenciosos en la interfaz |
| Inyección de objetos y rutas no literales (INC-11) | ESLint-security | Patrones inseguros | ISO/IEC 25010 (mantenibilidad) | Falsos positivos revisados, sin documentar en el código |
| Secreto JWT por defecto (INC-02) | Script de verificación (no lo detectó ninguna herramienta estática) | CWE-798, OWASP A07 | Ley 21.719 (deber de seguridad); ISO/IEC 27001 (controles criptográficos) | Cualquiera puede firmar un token de administrador |

Lectura crítica. La puerta de calidad por defecto de SonarQube aparece como aprobada porque evalúa solo el código nuevo; sobre el código completo la calificación es C en seguridad y fiabilidad, y el propio panel advierte que la edición Community no analiza vulnerabilidades de inyección. El hallazgo más grave (INC-02) no lo detectó ninguna herramienta estática. Por eso el dictamen no se apoya en la puerta de calidad sino en la combinación de herramientas, casos negativos y revisión dirigida.

### 6.7 Mejora continua

La suite automatizada se repite en menos de 10 segundos y JMeter y SonarQube quedaron con scripts reproducibles (jmeter/ejecutar.sh y sonar-project.properties). Se propone incorporarlos a la integración continua y usar como indicador el número de incidentes críticos y graves abiertos.

## 7. Conclusiones y recomendaciones

El plan alcanzó cobertura de diseño completa sobre los 45 requisitos de Tramoya y cobertura de ejecución de 95,6 %. Las funciones y reglas de negocio propias del dominio de eventos se comportan según el ERS (39 de 39 pruebas automatizadas, 93,3 % de líneas cubiertas) y el rendimiento cumple con holgura (29,32 ms de promedio con 200 usuarios en JMeter). La seguridad, en cambio, no alcanza el nivel exigido: hay un incidente crítico y cinco graves abiertos.

Sobre la estrategia: los defectos relevantes aparecieron en los casos negativos, en la revisión de configuración, en el análisis estático y en la prueba multimotor, no en los casos funcionales. Usar varias herramientas de análisis estático se justificó: solo SonarQube detectó INC-16.

| N° | Acción | Plazo | Criticidad |
|---|---|---|---|
| 1 | Eliminar el secreto JWT por defecto y abortar el arranque si no está definido (INC-02). | Inmediata | Crítico |
| 2 | Validar el largo del correo antes de la expresión regular y reemplazarla por una sin retroceso (INC-16). | Urgente | Grave |
| 3 | Actualizar Express y compression y repetir npm audit (INC-01). | Urgente | Grave |
| 4 | TLS en proxy inverso, HSTS, helmet y CORS restringido (INC-03, INC-09). | Urgente | Grave / Moderado |
| 5 | Cifrar cotizaciones y contratos en reposo (INC-04). | Urgente | Grave |
| 6 | Limitar intentos de inicio de sesión (INC-05). | Urgente | Grave |
| 7 | Vencimiento a 7 días y revocación del enlace de cotización (INC-08); supresión de datos personales (INC-06). | Próxima iteración | Moderado |
| 8 | Persistir la revocación de tokens (INC-10) y repetir JMeter con PostgreSQL (INC-07). | Próxima iteración | Moderado |
| 9 | Pruebas con usuarios mayores, Edge por separado y monitoreo de disponibilidad en producción. | Antes del despliegue | Cobertura |
| 10 | Corregir INC-11, INC-12 e INC-15. | Según disponibilidad | Leve |

## 8. Informe de certificación final

| Campo | Valor |
|---|---|
| **Producto** | Tramoya 1.0 (API Express + frontend React), imagen Docker tramoya:latest |
| **Especificación** | docs/ERS_Tramoya.md, 45 requisitos |
| **Fecha y responsable** | 28-10-2026, Jonathan Larraguibel (autor del producto y de las pruebas) |
| **Herramientas** | Jest, JMeter, SonarQube, Lighthouse, Playwright con axe-core, ESLint, njsscan, npm audit, autocannon, Docker |
| **Requisitos conformes** | 32 de 45 (71,1 %) |
| **Requisitos con incidente** | 10 (NFR-SEG-1, 3, 5, 8, 9; RF-1.2; NFR-USAB-2, USAB-3; NFR-COMPAT-1; RB-8) |
| **Parciales o no verificados** | 1 parcial (NFR-USAB-1) y 2 no verificados (NFR-DIS-1, DIS-2) |
| **Incidentes abiertos** | 1 crítico, 5 graves, 4 moderados y 3 leves |

### 8.1 Resultado por característica (ISO/IEC 25010)

| Característica | Resultado | Fundamento |
|---|---|---|
| **Adecuación funcional** | Conforme | 17 de 17 RF probados; 7 de 8 RB conformes; RB-8 incumple el vencimiento del enlace (INC-08). |
| **Eficiencia de desempeño** | Conforme | JMeter: 1,08 ms (10 usuarios) y 29,32 ms (200 usuarios), 0 % de error; LCP móvil 1.396 ms. |
| **Compatibilidad** | Conforme con observaciones | Chromium y Firefox 18/18; WebKit 16/18 (INC-15); responsivo en tres tamaños. |
| **Usabilidad** | Conforme con observaciones | 0 violaciones WCAG 2.1 AA; faltan pruebas con usuarios; INC-12 e INC-15. |
| **Fiabilidad** | Conforme con observaciones | Respaldo y restauración probados; SonarQube fiabilidad C por 9 promesas sin manejo en el frontend (INC-11); disponibilidad no verificada. |
| **Seguridad** | No conforme | INC-02 crítico; INC-01, 03, 04, 05 y 16 graves; SonarQube seguridad C. |
| **Mantenibilidad** | Conforme | SonarQube mantenibilidad A, 0 % de duplicación, 3 observaciones menores. |

### 8.2 Dictamen

**NO CERTIFICADO PARA PRODUCCIÓN.** Tramoya cumple sus requisitos funcionales y de rendimiento, pero no cumple los de seguridad: el criterio de salida del plan impide certificar con un incidente crítico (INC-02) y cinco graves abiertos (INC-01, INC-03, INC-04, INC-05 e INC-16). El producto sí se considera apto para un ambiente de demostración con datos sintéticos.

### 8.3 Condiciones para certificar

- Cerrar INC-02 e INC-16 y volver a ejecutar NF-04, NF-06 y un caso de regresión para la expresión regular.
- Cerrar INC-01, INC-03, INC-04 e INC-05 y volver a ejecutar NF-01 a NF-05 y la suite completa (Jest, E2E en los tres motores, JMeter y SonarQube).
- SonarQube con calificación de seguridad A y npm audit sin vulnerabilidades altas.

- Antes de producción: pruebas con al menos cinco usuarios, incluidas personas mayores; medición de disponibilidad; cierre de INC-08 para cumplir RB-8.

### 8.4 Limitaciones del dictamen

Producto y pruebas del mismo autor, sin revisión independiente; base SQLite; entorno local; sin usuarios reales ni producción; datos sintéticos. El dictamen describe el estado del producto el 28-10-2026.

# Anexo A. Evidencia de ejecución

*Salidas reales de cada herramienta, copiadas de los archivos generados el 28-10-2026 en la carpeta evidencia.*

## A.1 Pruebas automatizadas y cobertura (Jest)

```
respaldo.test.js
   PASA  NF-10 respaldo y restauracion recuperan datos y documentos tras perdida total
   PASA  NF-10 un respaldo alterado es rechazado
tramoya.test.js
   PASA  RF-1 Autenticacion y sesion > CP-01 RF-1.1 login exitoso entrega JWT
   PASA  RF-1 Autenticacion y sesion > CP-02 RF-1.1 login con clave incorrecta es rechazado sin revelar el motivo
   PASA  RF-1 Autenticacion y sesion > CP-03 RF-1.2 logout revoca el token
   PASA  RF-1 Autenticacion y sesion > CP-04 NFR-SEG-9 sin token no se accede a recursos
   PASA  RF-2 Registro y productora > CP-05 NFR-SEG-2 la contrasena se guarda con hash bcrypt
   PASA  RF-2 Registro y productora > CP-06 RF-2.1 politica de contrasenas (12 car, may, min, num, simbolo)
   PASA  RF-2 Registro y productora > CP-07 RF-2.2/2.3 quien crea la productora queda como administrador
   PASA  RF-2 Registro y productora > CP-08 RB-1 correo de productora no puede repetirse
   PASA  RF-3 Roles > CP-09 RF-3.1 admin asigna rol coordinador y este puede consultar
   PASA  RF-3 Roles > CP-10 RF-3.2 / RB-4 coordinador no puede crear clientes
   PASA  RF-3 Roles > CP-11 RF-3.3 admin quita a un usuario de la productora
   PASA  RF-3 Roles > CP-12 RB-2 usuario de otra productora no accede a datos (aislamiento)
   PASA  RF-4 Clientes organizadores > CP-13 RF-4.1 crear y listar con paginacion y filtro
   PASA  RF-4 Clientes organizadores > CP-14 RF-4.3 validacion de campos (nombre con caracteres no permitidos)
   PASA  RF-4 Clientes organizadores > CP-15 RF-4.2 eliminacion logica exige confirmacion
   PASA  RF-4 Clientes organizadores > CP-16 NFR-SEG-5 SQL injection en filtro no altera la consulta
   PASA  RF-4 Clientes organizadores > CP-17 NFR-SEG-5 XSS en campo libre se almacena escapado
   PASA  RF-4 Clientes organizadores > CP-31 RF-4.3 RUT con digito verificador incorrecto es rechazado
   PASA  RF-4 Clientes organizadores > CP-32 RF-4.3 tipo de cliente distinto de persona o empresa es rechazado
   PASA  RF-5 Eventos, cotizacion y contrato > CP-18 RF-5.1 / RB-3 crear evento asociado a un cliente queda
cotizado
   PASA  RF-5 Eventos, cotizacion y contrato > CP-19 RF-5.1 fecha, recinto o aforo invalidos son rechazados
   PASA  RF-5 Eventos, cotizacion y contrato > CP-20 RF-5.4 estado del evento segun confirmacion y fecha
   PASA  RF-5 Eventos, cotizacion y contrato > CP-21 RF-5.2/5.3 subir contrato PDF, se guarda en storage interno y
se referencia en BD
   PASA  RF-5 Eventos, cotizacion y contrato > CP-22 RF-5.2 formato no permitido (.exe o PDF falso) es rechazado
   PASA  RF-5 Eventos, cotizacion y contrato > CP-23 RF-5.5 enlace de cotizacion descarga la cotizacion
   PASA  RF-5 Eventos, cotizacion y contrato > CP-24 NFR-SEG-4 descarga de documento de otra productora es denegada
   PASA  RF-5 Eventos, cotizacion y contrato > CP-33 RB-8 monto que no es entero positivo en pesos es rechazado
   PASA  RF-5 Eventos, cotizacion y contrato > CP-34 RB-7 un evento no se confirma sin contrato PDF adjunto
   PASA  RF-5 Eventos, cotizacion y contrato > CP-35 RB-6 no se confirman dos eventos en el mismo recinto y fecha
   PASA  RF-5 Eventos, cotizacion y contrato > CP-36 RB-4 coordinador no puede confirmar eventos ni adjuntar
documentos
   PASA  RF-5 Eventos, cotizacion y contrato > CP-37 RF-5.5 sin cotizacion no se genera enlace (el contrato no se
comparte)
   PASA  RF-6 Auditoria > CP-25 RF-6.1 acciones criticas quedan registradas
   PASA  RF-6 Auditoria > CP-26 coordinador no puede leer la auditoria
   PASA  Pruebas complementarias > CP-27 NFR-SEG-6 la auditoria no almacena contrasenas ni hashes
   PASA  Pruebas complementarias > CP-28 NFR-USAB-4 flujo cliente -> eventos con estado calculado
   PASA  Pruebas complementarias > CP-30 RF-4.1 cliente sin campos opcionales (como envia el formulario)
   PASA  Pruebas complementarias > CP-29 RF-5.2 subida de un PDF de 5 MB en menos de 10 segundos
Total: 39 | Pasaron: 39 | Fallaron: 0
```

```
----------------|---------|----------|---------|---------|-------------------------------------------------
File            | % Stmts | % Branch | % Funcs | % Lines | Uncovered Line #s
----------------|---------|----------|---------|---------|-------------------------------------------------
All files       |   85.01 |    73.68 |      88 |   93.28 |
 scripts        |   88.23 |       50 |     100 |   90.32 |
  respaldo.js   |   88.23 |       50 |     100 |   90.32 | 43-45
 src            |   84.66 |    74.77 |   86.95 |   93.65 |
  app.js        |   83.02 |       72 |   82.35 |   92.69 | 41,95,109-110,114-115,130-135,280-281,313-314
  db.js         |     100 |        0 |     100 |     100 | 3
  eventos.js    |     100 |      100 |     100 |     100 |
  validacion.js |   92.59 |    85.71 |     100 |     100 | 4,13,28,38
----------------|---------|----------|---------|---------|-------------------------------------------------
```

## A.2 Análisis estático: SonarQube

```
SonarQube Community 26.10 (Docker local), proyecto tramoya: src, frontend/src y scripts, cobertura desde Jest (lcov)
  alert_status: OK
  bugs: 9
  code_smells: 3
  coverage: 68.9
  duplicated_lines_density: 0.0
  line_coverage: 66.3
  ncloc: 816
  reliability_rating: C
  security_hotspots: 0
  security_rating: C
  security_review_rating: A
  sqale_rating: A
  vulnerabilities: 3
Incidencias abiertas: 15
  RELIABILITY / MEDIUM: 12
  SECURITY / LOW: 1
  SECURITY / MEDIUM: 2
  - frontend/src/App.jsx:137 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:141 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:219 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:225 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:230 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:297 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:298 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:299 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
  - frontend/src/App.jsx:345 [MEDIUM] javascript:S9383 Promesa sin manejo de error (await, .catch o void).
```

```
  - src/app.js:20 [LOW] javascript:S5689 This framework implicitly discloses version information by default. Make sure it is
safe here.
  - src/app.js:21 [MEDIUM] javascript:S5122 Make sure that enabling CORS is safe here.
  - src/app.js:24 [MEDIUM] javascript:S5693 Make sure the content length limit is safe here.
  - src/app.js:169 [MEDIUM] javascript:S7773 Prefer `Number.parseInt` over `parseInt`.
  - src/app.js:170 [MEDIUM] javascript:S7773 Prefer `Number.parseInt` over `parseInt`.
  - src/validacion.js:10 [MEDIUM] javascript:S8786 Simplify this regular expression to reduce its runtime, as it has super-
linear performance due to backtracking.
Puntos criticos de seguridad (hotspots): 0
```

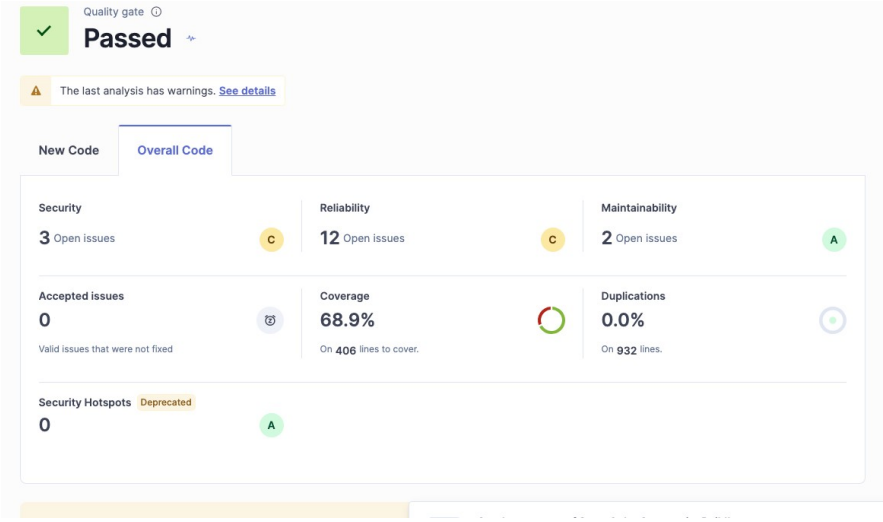



*Figura A.1. Panel de SonarQube sobre el código completo: seguridad C, fiabilidad C, mantenibilidad A, cobertura 68,9 %.*

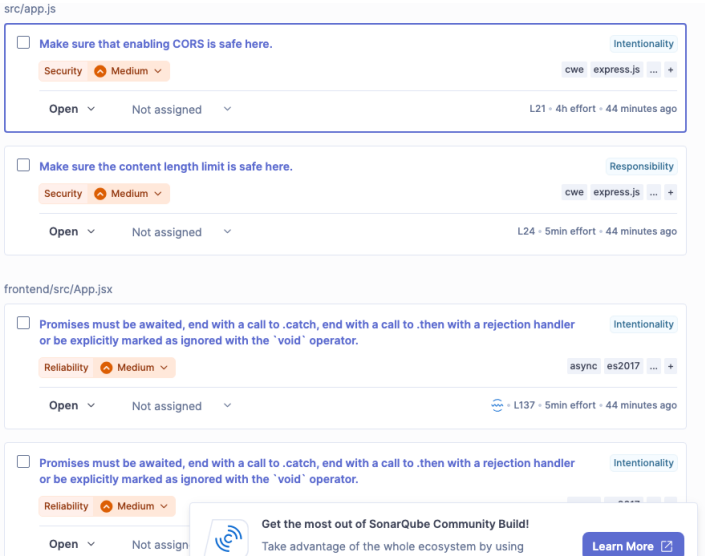



*Figura A.2. Incidencias de SonarQube: CORS (S5122), límite de subida (S5693) y promesas sin manejo (S9383).*

## A.3 Análisis estático: ESLint y njsscan

```
src/app.js
   23:3   warning  Found mkdirSync from package "fs" with non literal argument at index 0      security/detect-non-
literal-fs-filename
  151:11  warning  Generic Object Injection Sink                                              security/detect-
object-injection
  151:33  warning  Generic Object Injection Sink                                              security/detect-
object-injection
  151:64  warning  Function Call Object Injection Sink                                        security/detect-
object-injection
  251:5   warning  Found writeFileSync from package "fs" with non literal argument at index 0  security/detect-non-
literal-fs-filename

src/validacion.js
  34:20  warning  Function Call Object Injection Sink  security/detect-object-injection
  53:48  warning  Generic Object Injection Sink        security/detect-object-injection

✖ 7 problems (0 errors, 7 warnings)
```

```
njsscan 1.0.2: join_resolve_path_traversal | WARNING | CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') | A5: Broken Access Control | lineas ['app.js:276']
```

## A.4 Dependencias: npm audit --omit=dev

```
npm audit --omit=dev (28-10-2026)
9 vulnerabilities (4 low, 1 moderate, 4 high)
Paquetes afectados:
body-parser  <=1.20.8 || 2.0.0-beta.1 - 2.0.2
compression  <=1.8.1
cookie  <0.7.0
on-headers  <1.1.0
path-to-regexp  <=0.1.12
qs  <=6.16.0
send  <0.19.0
Express instalado: 4.19.2
Nuevo respecto del 25-10: compression <=1.8.1 (alta) y on-headers <1.1.0 (baja).
```

## A.5 Rendimiento y carga: JMeter y autocannon

```
JMeter 5.6.3, modo no grafico, rampa 5 s, duracion 30 s, GET listado de clientes + GET eventos de un cliente (con JWT)
10 usuarios: muestras 250323 | errores 0 (0.00 %) | promedio 1.08 ms | mediana 1 ms | p90 2 ms | p95 2 ms | p99 4 ms | max 33 ms | rendimiento 8390 sol/s
200 usuarios: muestras 185729 | errores 0 (0.00 %) | promedio 29.32 ms | mediana 26 ms | p90 41 ms | p95 47 ms | p99 69 ms | max 312 ms | rendimiento 6196 sol/s
```

| Requests | Executions | | | Response Times (ms) | | | | | | | Throughput | Network (KB/sec) | |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| Label | #Samples | FAIL | Error % | Average | Min | Max | Median | 90th pct | 95th pct | 99th pct | Transactions/s | Received | Sent |
| **Total** | **250323** | **0** | **0.00%** | **1.08** | **0** | **33** | **1.00** | **2.00** | **2.00** | **4.00** | **8389.68** | **7787.57** | **3289.51** |
| GET eventos de un cliente | 125159 | 0 | 0.00% | 1.07 | 0 | 16 | 1.00 | 2.00 | 3.00 | 4.00 | 4199.54 | 1964.43 | 1607.64 |
| GET listado de clientes | 125164 | 0 | 0.00% | 1.08 | 0 | 33 | 1.00 | 2.00 | 3.00 | 4.00 | 4195.07 | 5825.57 | 1683.76 |

*Figura A.3. Reporte de JMeter con 10 usuarios: 0 % de error, promedio 1,08 ms.*

| Requests | Executions | | | Response Times (ms) | | | | | | | Throughput | Network (KB/sec) | |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| Label | #Samples | FAIL | Error % | Average | Min | Max | Median | 90th pct | 95th pct | 99th pct | Transactions/s | Received | Sent |
| **Total** | **185729** | **0** | **0.00%** | **29.32** | **0** | **312** | **26.00** | **41.00** | **47.00** | **69.00** | **6195.72** | **5752.43** | **2429.31** |
| GET eventos de un cliente | 92818 | 0 | 0.00% | 29.27 | 0 | 290 | 25.00 | 38.00 | 43.00 | 58.00 | 3098.48 | 1449.39 | 1186.14 |
| GET listado de clientes | 92911 | 0 | 0.00% | 29.38 | 0 | 312 | 25.00 | 38.00 | 44.00 | 57.00 | 3099.51 | 4304.21 | 1244.04 |

*Figura A.4. Reporte de JMeter con 200 usuarios: 0 % de error, promedio 29,32 ms, p99 69 ms.*

*El reporte HTML completo de JMeter está en evidencia/jmeter_10 y evidencia/jmeter_200. Contraste con autocannon (15 s, listado de clientes):*

```
10 conexiones:
{"conexiones":10,"duracion_s":15,"req_total":133905,"req_seg":8927.87,"lat_prom_ms":0.38,"lat_p50_ms":0,"lat_p97_5_ms":2,"lat_p99_ms":2,"lat_max_ms":19,"errores":0,"non2xx":0,"timeouts":0}
200 conexiones:
{"conexiones":200,"duracion_s":15.02,"req_total":129019,"req_seg":8602.4,"lat_prom_ms":22.73,"lat_p50_ms":21,"lat_p97_5_ms":28,"lat_p99_ms":31,"lat_max_ms":2297,"errores":0,"non2xx":0,"timeouts":0}
```

## A.6 Revisión de configuración de seguridad (verificacion_config.js)

```
EV-BRUTA: 30 intentos fallidos -> 401 | login correcto tras 30 fallos -> 200
EV-HEADERS: {"x-powered-by":"Express","access-control-allow-origin":"*"}
EV-ENLACE: descarga 8 dias despues -> 200 | ruta de revocacion: no existe
EV-SECRET: token valido con el secreto por defecto (sin JWT_SECRET definido)
```

```
a@ + puntos + espacio | largo 5003 | ms 20
a@ + puntos + espacio | largo 20003 | ms 318
a@ + puntos + espacio | largo 50003 | ms 2014
a@ + a.a... + @ | largo 5003 | ms 10
a@ + a.a... + @ | largo 20003 | ms 159
a@ + a.a... + @ | largo 50003 | ms 1002
a@a + .a repetido + espacio | largo 5004 | ms 11
a@a + .a repetido + espacio | largo 20004 | ms 152
a@a + .a repetido + espacio | largo 50004 | ms 1042
EV-REDOS: POST /api/auth/register sin autenticacion, correo de 95003 caracteres -> HTTP 400 en 8316 ms (el proceso no atiende otras solicitudes mientras tanto)
```

*EV-BRUTA: sin límite de intentos (INC-05). EV-HEADERS: X-Powered-By, CORS abierto, sin HSTS (INC-03, INC-09). EV-ENLACE: el enlace de cotización sigue funcionando a los 8 días y no hay revocación*

*(INC-08). EV-SECRET: secreto por defecto (INC-02). EV-REDOS y las mediciones previas: tiempo de la validación de correo creciendo de forma cuadrática (INC-16).*

## A.7 Interfaz: extremo a extremo, accesibilidad y compatibilidad (Playwright + axe-core)

```
Motor: chromium 156.0.8078.4
PASA  E2E-01a politica de contrasena visible al usuario La contraseña debe tener al menos 12 caracteres, con mayúscula, minúscula,
número y símbolo.
PASA  E2E-01b registro e inicio de sesion llevan a crear productora
PASA  AXE crear productora 0 violaciones WCAG 2.1 A/AA
PASA  E2E-02 crear productora deja al usuario como administrador en Clientes
PASA  E2E-03b RUT con digito verificador incorrecto muestra mensaje claro Revise los datos del cliente: el nombre solo admite letras,
números y signos básicos, y el RUT debe tener un dígito verificador válido (por ejemplo 12.345.678-5).
PASA  AXE clientes 0 violaciones WCAG 2.1 A/AA
PASA  E2E-03 mensaje amigable ante dato invalido Revise los datos del cliente: el nombre solo admite letras, números y signos básicos, y
el RUT debe tener un dígito verificador válido (por ejemplo 12.345.678-5).
PASA  E2E-04 evento nuevo queda en estado Cotizado estado=Cotizado
PASA  E2E-05a RB-7 no permite confirmar sin contrato y lo explica Para confirmar el evento primero adjunte el contrato en PDF.
PASA  E2E-05b con contrato adjunto el evento a 20 dias queda Proximo estado=Próximo
PASA  AXE eventos 0 violaciones WCAG 2.1 A/AA
PASA  E2E-06 primer Tab enfoca el enlace "Saltar al contenido" A.saltar:Saltar al contenido
PASA  E2E-07 login completo usando solo teclado
PASA  E2E-08 controles interactivos de al menos 44 px todos >= 44 px
PASA  E2E-09 tipografia base de al menos 12 px (ERS 3.1.1) 16px
PASA  RESP-movil (375x812) sin desborde horizontal
PASA  RESP-tablet (768x1024) sin desborde horizontal
PASA  RESP-escritorio (1440x900) sin desborde horizontal


Total: 18 | Pasaron: 18 | Fallaron: 0
```

```
Motor: chromium 156.0.8078.4 -> Total: 18 | Pasaron: 18 | Fallaron: 0
Motor: firefox 157.0 -> Total: 18 | Pasaron: 18 | Fallaron: 0
Motor: webkit 27.2 -> Total: 18 | Pasaron: 16 | Fallaron: 2
   FALLA E2E-06 primer Tab enfoca el enlace "Saltar al contenido" INPUT.:
   FALLA E2E-07 login completo usando solo teclado
```

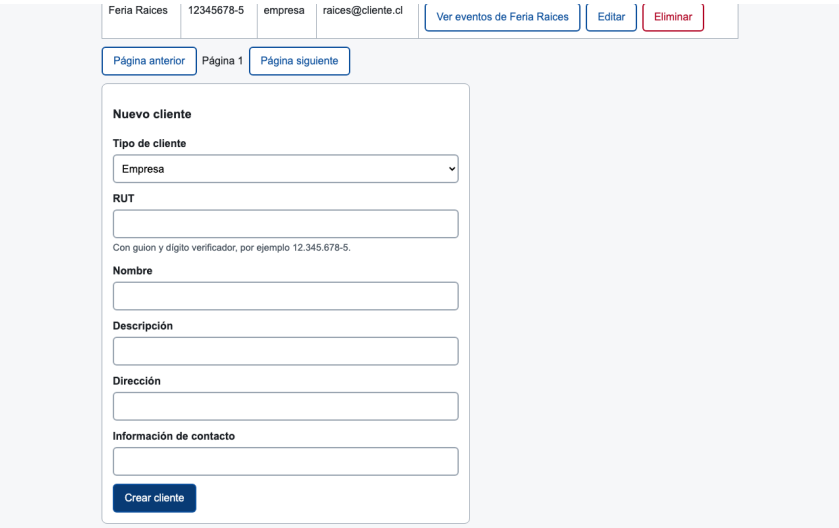



*Figura A.5. Clientes con RUT y tipo (Chromium, 1280 x 800).*

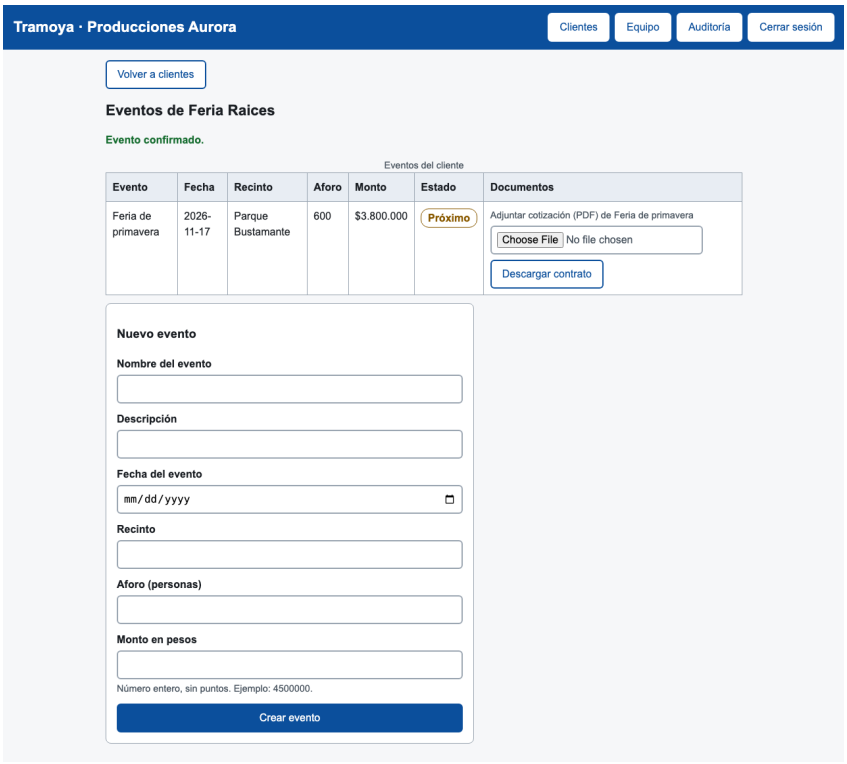



*Figura A.6. Eventos de un cliente: evento confirmado con contrato, estado Próximo.*

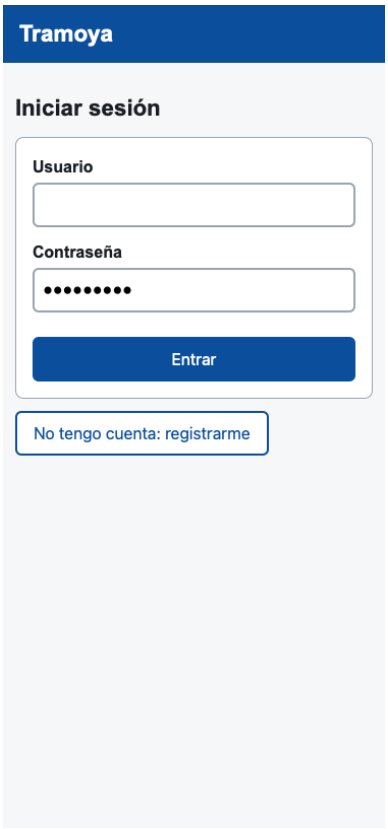



*Figura A.7. Vista móvil en WebKit (375 x 812) sin desplazamiento horizontal.*

## A.8 Página principal (Lighthouse 13.5.0)

```
mobile: Lighthouse 13.5.0 | puntajes {'rendimiento': 100, 'accesibilidad': 100, 'buenas_practicas': 100, 'seo': 91} | LCP
1396 ms | FCP 1.4 s | TBT 20 ms | CLS 0 | fallas: robots-txt
desktop: Lighthouse 13.5.0 | puntajes {'rendimiento': 100, 'accesibilidad': 100, 'buenas_practicas': 100, 'seo': 91} | LCP
327 ms | FCP 0.3 s | TBT 0 ms | CLS 0 | fallas: robots-txt
```

## A.9 Respaldo y recuperación (NF-10)

```
    NF-10 tiempo respaldo+restauracion (ms): 3 | filas antes: [ 1, 1, 1, 1, 1 ]
Tests:       2 passed, 2 total
```

## A.10 Despliegue en Docker (NF-16)

```
HTTP/1.1 200 OK
X-Powered-By: Express
Access-Control-Allow-Origin: *
Content-Type: application/json; charset=utf-8
Content-Length: 11
ETag: W/"b-Ai2R8hgEarLmHKwesT1qcY913ys"
Date: Wed, 28 Oct 2026 19:30:19 GMT
Connection: keep-alive
Keep-Alive: timeout=5


{"ok":true}--- GET / (frontend)
HTTP 200, 564 bytes
--- usuario del proceso
uid=1000(node) gid=1000(node) groups=1000(node)
imagen: tramoya:latest tamano: 251MB
tramoya
```

## Anexo B. Descripción del producto

El código fuente, las pruebas y la evidencia están publicados en https://github.com/jhonnylarry/tramoya, con instrucciones para instalar el producto y reproducir cada ejecución.

| Componente | Descripción |
|---|---|
| **docs/ERS_Tramoya.md** | Especificación de requisitos: 17 RF, 20 NFR y 8 RB, con criterio de aceptación y justificación de negocio. |
| **src/app.js** | API REST: autenticación, productoras, equipo y roles, clientes, eventos, cotización y contrato, confirmación, enlace de cotización y auditoría. |
| **src/db.js** | Esquema: usuarios, productoras, productora_usuarios, clientes, eventos, documentos, enlaces, auditoria. |
| **src/validacion.js** | Contraseña, correo, nombre, fecha, RUT (módulo 11), monto y aforo; saneamiento de texto. |
| **src/eventos.js** | Cálculo del estado del evento (RF-5.4). |
| **frontend/** | React 19 con Vite: acceso, productora, clientes con RUT, eventos con estados, cotización y contrato, confirmación, equipo y auditoría. |
| **test/tramoya.test.js, test/respaldo.test.js** | 37 casos CP y 2 de respaldo con Jest y Supertest. |
| **e2e/** | Playwright + axe-core (MOTOR=chromium, firefox o webkit) y Lighthouse. |
| **jmeter/** | Plan plan_tramoya.jmx, preparación de datos y ejecutar.sh (modo no gráfico). |
| **sonar-project.properties** | Configuración del análisis de SonarQube con cobertura de Jest. |
| **Dockerfile, docker_verificar.sh** | Imagen de dos etapas con usuario sin privilegios y script de verificación. |
| **evidencia/** | Salidas de todas las herramientas, reportes HTML de JMeter y capturas. |

### *Endpoints*

```
POST /api/auth/register | /api/auth/login | /api/auth/logout
GET/POST /api/productoras            GET/POST/PUT/DELETE /api/productoras/:id/usuarios[/:uid]
GET/POST /api/productoras/:id/clientes   PUT/DELETE /api/clientes/:id
POST /api/eventos                    GET /api/clientes/:id/eventos
POST /api/eventos/:id/documentos     POST /api/eventos/:id/confirmar   GET /api/documentos/:id
POST /api/eventos/:id/compartir      GET /api/cotizacion/:token
GET /api/productoras/:id/auditoria   GET /api/health
```

### *Comandos para reproducir*

```
npm install && (cd frontend && npm install && npm run build)
npx jest --coverage
npx eslint src ; njsscan src ; npm audit --omit=dev
PORT=3100 JWT_SECRET=x node src/server.js &
BASE=http://localhost:3100 MOTOR=webkit node e2e/e2e.js
BASE=http://localhost:3100/ node e2e/lighthouse.mjs
./jmeter/ejecutar.sh 200
sonar-scanner -Dsonar.host.url=http://localhost:9000
./docker_verificar.sh
```